Healthcare Practice Transition Brokerage Platform — Complete PRD (v2.0)

Nov 8, 2026 · @Anu

1. Executive summary

Build a broker-led transaction platform for selling dental, veterinary and specialist medical practices: anonymised listings at the front, and a broker CRM and confidential deal room behind them. Release 1 is a 37-feature, security-complete product that a pilot can run on real deals in about 21 weeks; Release 1.1 adds 8 operational features by week 24 (planning estimates).

This is the single, complete PRD (version 2.0). It replaces "Dental Practice Transition Brokerage Platform (India-first): Research & PRD" (v1, 7 November 2026) and its audit. It keeps v1's research, requirements, security design and stack, and corrects 25 inconsistencies (Appendix A).

Decision	Recommendation	Section
Positioning	Broker-led hybrid: anonymised listings feed an internal CRM and deal workspace; not an open marketplace	5
Specialties	Dental, veterinary and specialist medical in one data model; each enabled per market by configuration	5, 17
Geography	One market at launch, chosen by configuration; India researched as the example; final choice awaits management	7
MVP	45 features: Release 1 (37) then Release 1.1 (8); confidentiality enforced on the server in four disclosure tiers	13, 14
Stack	Next.js, Node.js, Express.js, MongoDB (mandated) plus a shared Zod package, private object storage, Redis/BullMQ, a cloud KMS	16
Security	OWASP ASVS Level 2 target; staff MFA; field-level encryption; sealed audit log; malware scanning; 60-second signed URLs	19

Decision	Recommendation	Section
AI	None in the MVP; deterministic matching and valuation later	21
Valuation	Phase 2, after multiples are validated on real transactions	10, 27
Timeline	About 21 weeks to pilot with about 6.5 full-time people (2 backend, 2 frontend, 0.5 design, 1 QA, product owner)	24

Before build starts: management answers the business checklist (section 7), above all geography, launch specialties, brokerage model, deadline and team; counsel reviews ownership and licence-transfer rules per specialty, advertising rules, the NDA, the privacy notice and data-protection compliance (section 20).

Limits. Market and competitor research is from public pages, dated 7 November 2026 and India-focused. Targets, retention periods, rate limits and estimates are proposals. Nothing here is legal, tax or financial advice.

2. Problem statement

Owners of dental, veterinary and specialist medical practices who want to retire, exit or bring in a partner have no confidential, structured way to find qualified buyers, prove their numbers and run the deal; the brokerage team that serves them has no system to run that work. The pain points below come from the brief and from how competitors position themselves; they are hypotheses until interviews confirm them.

Participant	Pain point	How the platform responds
Seller (owner retiring or exiting)	Cannot find trustworthy buyers without telling staff, patients or clients	Anonymised listings; identity released only after NDA and broker approval
Seller	Does not know what the practice is worth	Valuation request handled by a broker (MVP); transparent preliminary estimate later (Phase 2), never presented as certified
Seller	Financial records are scattered or informal	Guided three-year financial intake and a categorised document checklist

Participant	Pain point	How the platform responds
Seller	Ownership transfer, lease and staff handover are unclear	Pipeline stages with gate checklists through post-sale handover
Buyer (associate, expanding owner, group, investor)	Cannot discover suitable practices	Search and filters by specialty, city, size and transition type; broker-curated shortlists
Buyer	Cannot verify revenue, assets or risk before committing time	Staged disclosure and a verified-document data room
Buyer	Needs financing and does not know what to prepare	Broker qualification step; lender integration later (Phase 3)
Broker	Leads, documents and conversations live in phones and spreadsheets	CRM with leads, tasks, notes and communication history
Broker	Cannot see where each deal is stuck	Kanban pipeline with configurable stages and gates
Broker	Coordinates NDAs, documents and offers by email	One workspace per deal with access logs

What this platform is not: a classifieds site or a clinical system. It stores no patient-identifiable data (dental or medical) and no client-identifiable data (veterinary).

3. Market research

The research below was done for India on 7 November 2026; it supports a hypothesis, not a sized market. If management chooses another launch geography (B1), equivalent research is needed first.

What the sources support (India)

- **Fragmentation.** Older press on Investcorp's investment in Global Dental Services said hospitals and chains were under 10% of dental practices and valued Indian dental services at about $3 billion; both figures are several years old.

- **Dentist counts conflict.** One industry interview cites 180,000 dentists and 125,000 clinics; a clinic-chain blog says about 300,000 dentists. Neither is an official register count.
- **Chains own rather than acquire.** Clove Dental, Sabka Dentist and Apollo are described as fully owning their centres; institutional demand for independent practices is unproven.
- **Visible supply is informal.** SureMedico's marketplace lists mostly equipment, chair-sharing and clinic setups, with clinic prices from roughly ₹1.5 lakh to ₹17 lakh.
- **Veterinary and specialist medical:** v1 did not research Indian volumes for these specialties; this is an open research item before enabling them.

Where the opportunity most likely sits (hypothesis): a confidential, broker-managed transition service for solo and small-group practices in metros: retiring owners, partner buy-outs and associate-to-owner sales. Nobody found in India offers structured financial disclosure, NDAs and a deal room for healthcare practices.

Cannot be verified from public sources: annual practice transactions and deal sizes; valuation multiples in use; quality of sellers' financial records; appetite of chains and investors.

Recommended validation: 15–20 interviews per launch specialty (owners aged 55+, associates, two chains' corporate development teams) and 10 real recent transactions, before finalising pricing and the valuation module.

4. Competitor analysis

No competitor found combines India-specific practice data, confidential listings, a data room and a broker CRM; the strongest transaction designs are US-only. Evidence comes from public homepages opened on 7 November 2026; nothing behind a login was inspected. V = visible on the public page; A = marketing claim not verified; U = unknown.

Platform	Model and target	Verified on public pages (V)	Gaps and notes
VetValue	Founder-led brokerage and platform for US veterinary owners	Three tracks (Grow, Connect, Share); free valuation page; gated member app	Veterinary only; no public listings; claims (A) of $1.3B+ transactions

Platform	Model and target	Verified on public pages (V)	Gaps and notes
Henry Schein Dental Practice Transitions	Corporate US dental brokerage	Coded blind listings; Preferred Purchaser form; NDA form; valuation enquiry; loan calculator	Broker-led; no visible self-serve deal room
The Practice Market	Free aggregator across 19 professions	No-login browsing; each listing links to its broker	Discovery only: no NDA, documents or deal tracking
Clinic Exchange	Peer-to-peer US dental marketplace	Tagline only: confidential listings, structured data rooms	U: workflows and pricing
Practice Transitions Group	Sell-side advisory for dental, medical, med spa, dermatology, behavioural health, veterinary	Per-specialty valuation calculators; public listings; buyer-list signup	Advisory-led; no platform workflow shown
SMERGERS	Horizontal Indian SME deal marketplace	Business, investor and advisor profiles; valuation calculator; "Clinics for sale" category	Not specialty-specific; no deal room
SureMedico	Free Indian dental network with buy/sell marketplace	Admin-approved listings; verified doctors; seller identity hidden until connect	Classifieds: no financial disclosure, NDA or pipeline
National Practice Sales	California brokerage: dental, medical, veterinary, optometry	Listings with price and gross income; full financials after NDA; five-stage seller process	One state; broker-led
Dental Acquisitions	US dental marketplace with a Deal Room	Listings masked to an area until NDA; invited attorneys, CPAs, lenders; valuation calculator	US only; workflow visuals labelled illustrative

Platform	Model and target	Verified on public pages (V)	Gaps and notes
Practice Buy Sell	Confidential brokerage claim	Lead-capture page only	Do not benchmark: placeholder testimonials and 555 phone number

Capability	Seen at	Planned
Masked or blind listings	Henry Schein, SureMedico, National Practice Sales, Dental Acquisitions	MVP
NDA before financials	Henry Schein, National Practice Sales, Dental Acquisitions	MVP (clickwrap; e-sign Phase 3)
Data room	Dental Acquisitions (V), Clinic Exchange (A)	MVP (uploads), Phase 2 (checklists)
Valuation tool	Most US competitors, SMERGERS	Phase 2
Broker CRM	Not seen publicly	MVP
Multi-specialty	Practice Transitions Group, National Practice Sales, The Practice Market	MVP by configuration

Implications: NDA-gated financials are table stakes; a deal room is the differentiator; the broker CRM gap is an assumption until confirmed by demos (risk R10).

5. Product vision and scope

The product is a broker-led transaction system with a controlled-access listing front end, for healthcare practices in general: one platform, with specialties and markets switched on by configuration.

Element	Statement
Mission	Help owners of dental, veterinary and specialist medical practices sell, exit or bring in partners confidentially and at a fair price, and help qualified buyers acquire with verified information
Vision	The system of record for healthcare practice transitions in each market served: every deal tracked from first enquiry to post-sale handover

Element	Statement
Value proposition	Sellers control who learns what and when; buyers see verified information in stages; brokers run every deal from one CRM and workspace
Users	Sellers; buyers (associates, expanding owners, groups, investors); the brokerage team; administrators; advisors invited per deal (Phase 2)
Not in scope	Clinical systems, patient or client records, payments, open classifieds, native apps, certified valuations

Option	Verdict	Reason
Open marketplace	Not for MVP	Needs two-sided liquidity; classifieds already own the casual end
Pure broker CRM	Too narrow	Tools without demand
Transaction management only	Partial	Strong at diligence, weak at discovery
Broker-led hybrid	**Adopt**	Listings generate demand; CRM and deal workspace deliver the service; every listing approved by the brokerage

5.1 What is configuration and what is code

Setting	Where it lives	Who changes it	Default
Specialty enabled per market	`specialtySettings` collection	Super Admin	Only confirmed specialties
Specialty fields, sub-specialties, extra document categories	Code: `packages/shared/specialties/*`	Engineering, via release	Dental, veterinary, specialist medical defined
Market: currency, fiscal calendar, regions, cities and zones, revenue bands, registration bodies	`marketConfigs` collection	Super Admin	One market

Setting	Where it lives	Who changes it	Default
Pipeline stages and gate checklists	`pipelineStages`	Brokerage Manager	Default stages (10K)
NDA template versions	`ndaTemplates`	Platform Admin after legal approval	None until approved
Model flags: `externalBrokersEnabled`, `sellerSelfListingEnabled`, `directMessagingEnabled`	Market configuration	Super Admin	All off

Success metrics (targets set by management, reported per specialty and market): approved listings; buyers qualified per listing; NDA-to-offer conversion; days from first enquiry to close; share of deals tracked end-to-end.

6. Business model

Recommended default: a success fee paid at closing by the seller, with optional paid services later. No fee levels are set because none has been confirmed.

Revenue option	Payer	Phase	Status
Success fee at closing	Seller (default)	MVP	Rate to be set by management (B7)
Listing or retainer fee	Seller	Optional	Management decision
Paid valuation report	Seller	Phase 2	Test: free valuation tools are common among competitors
Buyer premium access	Buyer	Phase 2	Likely keep free, as Henry Schein and The Practice Market do
Lender, legal or accounting referral fees	Third party	Phase 3	Needs legal review for conflicts

The MVP records fee amount and status per deal; it does not calculate or collect fees. Tax treatment of brokerage fees (GST in India) needs an accountant's confirmation.

Business metrics from day one: listings approved, buyer-to-NDA conversion, NDA-to-offer conversion, offer-to-close conversion, days per pipeline stage, fee revenue per closed deal.

7. Business decisions: confirmed, assumed, open

Four facts are confirmed by the brief, three were recorded in v1 as founder answers but need written confirmation, and fifteen decisions are open. Each open item has a design default so engineering can start; no default is a business decision.

7.1 Confirmed

Item	Source
The business serves dental, veterinary and specialist medical clinics	Written business description
Stack: Next.js, Node.js, Express.js, MongoDB	Written brief
Security requirements may not be weakened to simplify development	Written brief
No unnecessary AI features	Written brief

7.2 Recorded in v1, needs written confirmation

Item	v1 answer	Why it matters
Geography	India first	Currency, regulators, data residency, hosting, legal review
Who runs transactions	Internal brokerage team only	Permissions, fees, external brokers
MVP vertical	Dental only	Which specialty schemas and document lists ship first

7.3 Open questions for management

#	Decision	Options	Default until answered	Needed by
B1	Geography	India only · India first · another country first	One market by configuration; India seeded as example	Week 2
B2	Launch specialties	Dental · dental + veterinary · all three	All modelled; only confirmed ones enabled	Week 9

#	Decision	Options	Default until answered	Needed by
B3	Launch cities	One metro · several · national	Cities held in market configuration	Week 12
B4	Brokerage model	Internal only · + partner brokers · self-serve sellers with broker review	Internal only; every CRM record carries `brokerageId`	Week 3
B5	Representation	Seller only · both sides with disclosure	Seller-side	Week 3
B6	Buyer–seller communication	Broker-mediated only · direct when a broker enables it	Broker-mediated; no messaging in MVP	Week 9
B7	Fee structure	% success · tiered · fixed · retainer + success	Amount and status recorded, no calculation	Week 9
B8	Listing approval	Manager · manager or admin · two-person	Manager or admin; brokers recommend	Week 9
B9	NDA policy	Clickwrap · e-sign · platform NDA vs per listing; validity	Clickwrap, one versioned platform NDA, grants 90 days	Week 13
B10	Asking price visibility	Never public · after NDA · teaser	After NDA, only if the seller allows	Week 9
B11	Existing customer pipeline	None · spreadsheet · active deals	Assume a spreadsheet; lead import moves earlier if confirmed	Week 2
B12	Actual MVP deadline	Date or "when ready"	21 weeks to pilot	Week 1
B13	Available development team	Roles, seniority, time	2 BE, 2 FE, 0.5 design, 1 QA, PO	Week 1
B14	Hosting provider and region	Depends on B1 and legal advice	Provider-neutral design	Week 2
B15	Brand name and domain	–	Placeholder	Week 2

7.4 Assumptions (change any of them)

#	Assumption	Effect if wrong
A1	Brokers and managers are employees	Multi-organisation permissions earlier
A2	Sellers and buyers are individuals or small entities	Group acquirers need an organisation workflow
A3	English only at launch	Translation and layout work
A4	NDAs by clickwrap; e-signature in Phase 3	Earlier e-sign adds about 3 weeks
A5	25 MB file limit and the listed types	Chunked upload needed
A6	Team and timeline as in B12, B13	Plan scales roughly in proportion
A7	Valuation estimator waits for Phase 2	Moves earlier if internal pricing data exists
A8	MFA required for all staff	Must not be dropped (security)
A9	No patient- or client-identifiable data for any specialty	Clinical-data regulation would apply

8. User personas

Six working personas cover the MVP; they come from the brief, not user research, and should be revised after the interviews in section 3.

Persona	Type	Goal	Key concern	Main screens
Retiring owner (solo dentist, vet or specialist)	Primary seller	Sell and hand patients or clients to a trusted successor	Staff, patients or clients finding out early; fair price	Seller dashboard, sale request, documents, access requests
Exiting or partner-selling owner (multi-room or small group)	Primary seller	Sell all or part; possibly stay on clinically	Partial-sale terms; confidentiality	Seller dashboard, transition type
Associate-to-owner buyer	Primary buyer	Buy a first practice	Verifying revenue; financing readiness	Buyer profile, search, requests

Persona	Type	Goal	Key concern	Main screens
Established owner or group expanding	Secondary buyer	Add a location or acquire a neighbour	Speed; clean due diligence	Search, data room
Broker and brokerage manager	Primary internal	Run many deals without losing track	Stalled deals; missed follow-ups; document chaos	CRM, pipeline, tasks, moderation
Platform administrator	Internal	Keep the platform safe and configured	Access misuse; configuration errors	Admin dashboard, users, audit log, configuration

Investors and acquisition groups are buyers with an organisation. Legal and financial advisors are invited to a single deal with limited access (Phase 2).

9. User journeys

Seller, buyer and broker journeys run in parallel through one deal, with the broker as gatekeeper at every disclosure step.

Stage	Seller	Buyer	Broker
1. Enter	Registers, accepts privacy notice, verifies email	Same	Invited by an administrator; enrols MFA
2. Onboard	Submits sale request: specialty, city, transition type, confidentiality	Completes profile: specialties, cities, budget, size	Lead created and assigned by the manager
3. Prepare	Enters three years of financials; uploads documents	Uploads proof of funds and identity details	Reviews financials; verifies documents; qualifies buyer
4. List and discover	Previews anonymised listing; submits for review	Browses approved listings; expresses interest	Manager approves, requests changes or rejects
5. NDA and access	Sees anonymised requesters; may veto	Requests access; accepts current NDA	Approves with scope and expiry

Stage	Seller	Buyer	Broker
6. Diligence	Answers requests	Reviews data room	Tracks outstanding items
7. Offer	Reviews offers via broker	Submits offer	Records each offer and revision
8. Close	Signs agreements outside the platform (MVP)	Same	Moves deal through legal review and closing
9. Handover	Follows handover checklist	Same	Closes the deal; records fee

Pain points each journey must remove: repeated emailing of documents (seller), unverifiable numbers (buyer), deals dropping out of sight (broker). The disclosure workflow and state machines are drawn in Appendix C.

10. Functional requirements

Sixteen modules (A–P) cover the product; each names its features (section 13), rules and release. All API errors share one envelope `{ success:false, error:{ code, message, details[] } }` with 400 validation, 401 unauthenticated, 403 forbidden, 404 not found (also where 403 would reveal a record), 409 conflict, 422 business rule, 429 rate limit.

A. Authentication and onboarding (F01, F02, F04, F40, F53, F54 — Release 1)

- Registration: name, email, mobile, password (minimum 10 characters), role (seller or buyer only), privacy-notice acceptance. Registration responds identically whether or not the email exists.
- Email verification link: single use, 24 hours. Password-reset link: single use, 1 hour; a reset ends all sessions.
- Sessions: 15-minute access token plus a rotating refresh token in an httpOnly, Secure, `SameSite=Strict` cookie; reuse revokes the token family. Users list and revoke their sessions.
- Staff (brokers, managers, admins) are created by invitation only and must enrol TOTP MFA before any staff route works.
- Profile: personal details, organisation, and professional registration per specialty (registration body, number, jurisdiction).
- Rules: unverified users cannot request access to listings; only administrators grant verification badges.

B. Seller portal (F06, F07, F08 — Release 1)

- Sale request: specialty and sub-specialties (enabled ones only), city and zone, exact address (private), clinical units (chairs, exam rooms or consultation rooms), practitioners, staff counts, years in operation, transition type (complete sale, partial sale, partnership), specialty-specific fields (section 17), confidentiality preferences.
- Financials: revenue and expenses for the last three fiscal years in the market's currency and fiscal calendar, supported by documents.
- Photos and documents go to private storage; no photo is shown on a listing until a broker approves a version with identifying signage hidden.
- Practice status: Draft → Submitted → In review → Changes requested or Rejected or Approved; Withdrawn any time before Sold. Only the owner edits a Draft; after submission only a broker edits, and the seller sees a change log. Submission with missing fields returns 422 listing each one.

C. Buyer portal (F09, F14 Release 1; F52 Release 1.1)

- Profile: buyer type, target specialties, preferred cities, budget range, preferred size, transition preferences, financing status.
- Browse, filter, sort; express interest; request access; favourites (Release 1.1). All requests visible in one list with status.
- A buyer must be qualified by a broker before an access request is accepted. Budget and proof of funds are visible to brokers only.

D. Listings and discovery (F11, F12, F13 — Release 1; F15, F16 Phase 2)

Tier	Who sees it	Fields
0 Teaser	Any visitor (max 6 cached cards) or signed-in buyer	Generic title, specialty, city and zone, revenue band, clinical units, transition type
1 Verified buyer	Email-verified buyers	Adds years in operation, practitioners, locations, equipment summary, aggregated staff, Tier 1 specialty fields
2 NDA cleared	Accepted NDA + broker approval	Adds practice name, exact address, detailed financials, asking price if allowed, Tier 2 specialty fields
3 Data room	Per document, per buyer	Individual documents by category

- Search by keyword, specialty, city, revenue band, clinical units, transition type; sort by newest, revenue band, size; 20 per page.
- Revenue is a band at Tiers 0–1; exact figures only at Tier 2.
- Only Published listings appear; withdrawn or sold listings disappear immediately. Anonymisation is enforced by storing the listing as its own document, never by the frontend.
- Listing status: Published ⇄ Paused; Published → Under offer → Sold; Withdrawn.
- Phase 2: saved searches and alerts (F15); featured listings (F16) only after legal review of advertising rules.

E. Valuation (F32 Release 1.1; F33 Phase 2)

- Release 1.1: a valuation request creates a CRM lead; no figure is shown.
- Phase 2: preliminary low–mid–high range from revenue multiple, earnings multiple and asset floor; multiples are versioned configuration per specialty and market, set by the brokerage and validated on real deals. Output carries the text "Preliminary estimate, not a certified valuation, financial advice or a guaranteed price." Each estimate stores inputs and configuration version.

F. Matching (F34 Release 1.1; F35 Phase 2)

- Release 1.1: brokers maintain a manual shortlist of qualified buyers per listing.
- Phase 2: deterministic score; specialty is a hard filter; default weights location 30, budget 25, revenue and size 20, transition type 15, other 10 (configurable). Scores are visible to brokers only, with reasons.

G. Broker CRM (F25–F28 Release 1; F30 Release 1.1; F31 Phase 2)

- Records: leads, sellers, buyers, practices, each with owner, source, specialty and status. Leads are created by sale requests, buyer sign-ups, valuation requests, imports or manual entry.
- Managers assign and reassign leads and deals; every change is logged.
- Tasks with due date, assignee, linked record; overdue tasks on the dashboard and by email.
- Communication history (calls, meetings, messages logged manually); internal notes never returned to sellers or buyers.
- A broker sees only assigned records; a manager sees the whole brokerage.
- Release 1.1: analytics (deals per stage and broker, days in stage) and lead import from CSV (F61).

H. Confidentiality and NDA (F17, F18 — Release 1)

- NDA templates are versioned and marked approved only after legal sign-off. Buyers accept the current version by clickwrap; the system stores user, version, document hash, typed name, time and IP. The MVP records acceptance; enforceability is for counsel (e-signature Phase 3).
- Access request states: Requested → NDA pending → NDA accepted → Approved or Rejected or Vetoed → Expired or Revoked.
- A grant has a scope (tier, document categories), an expiry (default 90 days, B9) and a revocation reason; revocation applies on the next request. The seller may veto any buyer.

I. Documents and due diligence (F20–F22 Release 1; F23, F24 Phase 2)

- Categories: financial statements, tax records, licences and registrations, equipment inventory, lease, employment agreements, insurance, operational reports, agreements, plus specialty extras (section 17).
- Upload: PDF, DOCX, XLSX, JPG, PNG; 25 MB; content sniffing; malware scan; image metadata removed; available only after a clean scan.
- Versions kept on re-upload; expiry dates; review status Pending, Verified, Rejected, Needs update set by a broker.
- Downloads only through 60-second signed URLs after a permission check, each logged (F19).
- Phase 2: comments and approval workflow; due-diligence checklists per deal.

J. Offers (F36 Release 1.1; F51 Phase 2)

- Release 1.1: brokers record offers (price, structure, conditions, expiry, notes) as immutable records; revisions link to their parent.
- Phase 2: full offer and counter-offer workflow with seller accept or reject.

K. Transaction management (F29 — Release 1)

- Default stages (managers can configure): New lead → Buyer qualified → NDA → Information disclosure → Due diligence → Initial offer → Negotiation → Letter of intent → Legal review → Final agreement → Closing → Ownership transition → Post-sale handover; plus Lost and Withdrawn.
- Each stage can carry a checklist; a "hard gate" stage cannot be entered until its checklist is complete or a manager overrides with a reason. Moving backwards requires a reason.

- Legal review, agreements and closing happen outside the platform; the system records dates, parties and executed copies.

L. Notifications (F37 Release 1; F38 Phase 2)

- In-app and email for access requests, NDA status, document review, stage changes, reminders; non-critical types can be muted.
- Emails never contain confidential figures, document names or signed URLs; they link to the app.
- Phase 2: broker-mediated deal messaging; direct buyer–seller messaging only if B6 allows.

M. Administration (F39, F05 Release 1.1; F40, F41 Release 1)

- User management: invite staff, suspend users (ends all sessions immediately), reset MFA.
- Listing moderation queue (Approve, Request changes, Reject, each with a reason shown to the seller); NDA template management; audit log search and export.
- Release 1.1: KPI dashboard; manual verification queue.

N. Security operations (F42, F43, F55, F59, F60 — Release 1)

- Rate limiting and abuse controls; backups and monitoring; field-level encryption with managed keys; sealed audit log.
- Break-glass: an administrator may view one practice's confidential data for 60 minutes with a reason, MFA step-up and immediate notification to the brokerage manager; every read is audited.

O. Privacy and data rights (F56 — Release 1)

- Versioned privacy notice; consent records per purpose; users submit access, correction and deletion requests; admins decide them with reasons; records under legal hold are retained and the user is told why.
- Named grievance contact; breach-response runbook.

P. Configuration (F57, F58 — Release 1)

- Specialty registry with enablement per market; market configuration (currency, fiscal calendar, regions, cities, zones, revenue bands, registration bodies). Disabling a specialty hides it from new requests and search but keeps existing records.

11. Non-functional requirements

Targets are proposals sized for tens of brokers and a few thousand users.

Area	Requirement (proposed)	How it is checked
Performance	Listing search under 800 ms p95 with 5,000 listings; API reads under 500 ms p95	k6 load test before launch
Availability	99.5% monthly; maintenance outside 9:00–20:00 local time	Uptime monitor
Data residency	Data and files in the confirmed market's region (counsel to confirm)	Deployment review
Backup and recovery	Continuous backup with point-in-time recovery; daily snapshots kept 30 days; recovery point 1 hour, recovery time 4 hours	Quarterly restore drill
Security	OWASP ASVS Level 2 baseline (section 19)	Security tests, penetration test
Privacy	Notice, consent, data-rights and breach handling designed against the applicable law (DPDP Act and Rules if India)	Counsel review
Accessibility	WCAG 2.1 AA on all pages	axe plus manual audit
Browsers	Last two versions of Chrome, Edge, Safari, Firefox; Android Chrome, iOS Safari	Cross-browser run
Responsiveness	Usable from 360 px; CRM optimised for 1280 px and up	Playwright at 360, 768, 1280 px
Scalability	Stateless API behind a load balancer; storage and database scale independently	Architecture review
Observability	Structured logs with request IDs and redaction; error tracking; audit log separate from app log	Runbook
Maintainability	TypeScript strict; 80% unit coverage on services and policies; lint and type checks block merges	CI

Area	Requirement (proposed)	How it is checked
Localisation	English at launch; copy in a message catalogue; currency and dates from market configuration	Code review
Configurability	A new market or enabled specialty needs configuration only, not a code change, if its specialty schema exists	Contract tests

12. Roles and permissions

Permissions are enforced on the Express server by policy functions combining role with ownership, assignment and deal grants; hiding a button is never the control. The matrix below is also stored as data in `packages/shared/permissions.ts` and generates the authorisation test suite.

Roles: SA Super Admin · PA Platform Admin · BM Brokerage Manager · BR Broker · SE Seller · BU Buyer (IN Investor is a buyer with an organisation) · AV Advisor (legal or financial, Phase 2). Codes: All · Own · Asg (assigned) · Grant (deal-scoped grant) · BG (break-glass, logged) · – none.

Capability	SA	PA	BM	BR	SE	BU	AV
Invite or suspend users, reset MFA	All	All except SA	–	–	–	–	–
Configure specialties and markets	All	–	–	–	–	–	–
Manage NDA templates	All	All	View	View	–	–	–
Create or edit a practice	–	–	All	Asg	Own, draft only	–	–
Approve a listing	All	All	All	Recommend	–	–	–
View Tier 0–1 listing	All	All	All	All	Own	Verified	Grant
View Tier 2 (identity, financials)	BG	Listing fields only	All	Asg	Own	Grant	Grant
Upload documents	–	–	All	Asg	Own	Own qualification	Grant
Verify documents	All	–	All	Asg	–	–	–

Capability	SA	PA	BM	BR	SE	BU	AV
Download data-room documents	BG	–	All	Asg	Own	Grant	Grant
Approve an access request	–	–	All	Asg	Veto only	–	–
Record offers (R1.1)	–	–	On behalf	On behalf	–	Own (P2)	–
Move deals in the pipeline	View	View	All	Asg	–	–	–
Read internal notes	BG	–	All	Asg	–	–	–
View and export audit logs	All	All	Own brokerage	–	–	–	–
Decide privacy requests	All	All	–	–	–	–	–
Start break-glass	All	–	–	–	–	–	–
Configure pipeline stages	All	–	All	–	–	–	–
View analytics	All	All	Own brokerage	Own	–	–	–

Role	Dashboard
SA, PA	Queues, user counts, platform activity, configuration
BM	All deals, workload per broker, overdue tasks, listings pending approval
BR	Assigned leads, today's tasks, my pipeline
SE	Sale status, document checklist, access requests, notifications
BU	Search, interests, access status
AV (Phase 2)	Deal-scoped documents only

13. Canonical feature inventory

The platform has 60 features (F01–F61; F50 unused): 37 in Release 1, 8 in Release 1.1, 10 in Phase 2, 5 in Phase 3. The MVP (Release 1 + 1.1) is 45 features: 39 Must, 6 Should. This table is the only source of feature IDs.

Category: E essential business · S security-critical · O operational · A advanced · X optional. Complexity L/M/H is an estimate for engineers to recalibrate.

ID	Feature	Release	Cat.	MoSCoW	Cx	Depends on
F01	Registration and email verification	R1	E	Must	L	F56
F02	Login, secure sessions, password reset	R1	S	Must	M	F01
F03	Server-side RBAC and policy checks	R1	S	Must	M	F02
F04	Role-based onboarding and profiles	R1	E	Must	L	F02, F57
F05	Manual business and registration verification	R1.1	O	Should	L	F04, F20
F06	Practice sale request (draft, submit, withdraw)	R1	E	Must	M	F04, F57, F58, F59
F07	Three-year financial intake	R1	E	Must	M	F06, F59
F08	Confidentiality preferences	R1	E	Must	L	F06
F09	Buyer profile and preferences	R1	E	Must	L	F04
F10	Broker qualification of buyers	R1	E	Must	L	F09, F25
F11	Listing moderation and approval	R1	E	Must	M	F06
F12	Tiered anonymised listing responses	R1	E	Must	H	F03, F11, F57
F13	Search, filters, sort, pagination	R1	E	Must	M	F12
F14	Express interest	R1	E	Must	L	F12
F15	Saved searches and alerts	P2	A	Should	M	F13, F37
F16	Featured and recommended listings	P2	A	Could	M	F13; legal review
F17	NDA templates and clickwrap acceptance	R1	E	Must	M	F03
F18	Access requests, approval, veto, expiry, revocation	R1	E	Must	H	F10, F17
F19	Access and download logging	R1	S	Must	M	F18, F60
F20	Private upload with type, size and malware checks	R1	S	Must	H	F03
F21	Document categories, versions, expiry, review	R1	E	Must	M	F20
F22	Signed-URL downloads after permission check	R1	S	Must	M	F18, F20
F23	Document comments and approval workflow	P2	A	Should	M	F21
F24	Due-diligence checklists, completeness hints	P2	A	Should	M	F21
F25	CRM records: leads, sellers, buyers, practices	R1	E	Must	M	F03

ID	Feature	Release	Cat.	MoSCoW	Cx	Depends on
F26	Lead and deal assignment	R1	E	Must	L	F25
F27	Tasks, follow-ups, reminders	R1	E	Must	M	F25
F28	Communication log and internal notes	R1	E	Must	L	F25
F29	Pipeline: Kanban, configurable stages, gate checklists	R1	E	Must	M	F25
F30	Basic broker and manager analytics	R1.1	O	Should	M	F29
F31	Advanced analytics and funnels	P2	A	Could	M	F30
F32	Valuation request captured as a lead	R1.1	O	Should	L	F25
F33	Preliminary valuation estimator	P2	A	Should	M	F07; validated data
F34	Manual broker buyer shortlist	R1.1	O	Must	L	F10, F29
F35	Automated matching score	P2	A	Should	M	F09, F12
F36	Basic offer record	R1.1	O	Should	L	F29
F37	In-app and email notifications	R1	E	Must	M	F03
F38	Broker-mediated deal messaging	P2	A	Should	M	F37; B6
F39	Admin dashboard KPIs	R1.1	O	Must	M	F25
F40	User management and staff invitations	R1	E	Must	L	F03, F53
F41	Audit log viewer and export	R1	S	Must	M	F60
F42	Rate limiting, headers, validation, abuse controls	R1	S	Must	M	–
F43	Backups, monitoring, error tracking, log redaction	R1	S	Must	M	–
F44	E-signature integration	P3	A	Could	H	F17; legal advice
F45	Financing and lender integration	P3	A	Could	H	F09
F46	AI-assisted drafting and document reading	P3	X	Could	M–H	F21
F47	External brokers and multi-organisation support	P3	A	Could	H	F03; B4
F48	Advanced reporting	P3	A	Could	M	F31
F49	Invited legal and financial advisor access	P2	A	Should	M	F18
F50	Unused ID (not to be reused)	–	–	–	–	–
F51	Full offer and counter-offer management	P2	A	Should	M	F36
F52	Favourites	R1.1	O	Should	L	F12
F53	Staff multi-factor authentication	R1	S	Must	M	F02
F54	Session listing and revocation	R1	S	Must	M	F02
F55	Break-glass administrative access	R1	S	Must	M	F03, F53, F60

ID	Feature	Release	Cat.	MoSCoW	Cx	Depends on
F56	Privacy notice, consent, data-rights requests	R1	S	Must	M	–
F57	Specialty registry and enablement	R1	E	Must	M	–
F58	Market (geography) configuration	R1	E	Must	L	–
F59	Field-level encryption and key management	R1	S	Must	M	–
F60	Tamper-evident audit logging	R1	S	Must	M	–
F61	Lead import from spreadsheet	R1.1	O	Should	L	F25; B11

Won't have: patient or client records, payment collection, for-sale-by-owner public listings, native mobile apps, automated certified valuations.

14. MVP scope

Release 1 is the smallest complete product: a brokerage can take one practice from sale request to closing with confidentiality enforced on the server. Features that only make brokers faster are in Release 1.1; nothing security-critical is deferred.

Category	Release	Features	Count
Essential business	R1	F01, F04, F06–F14, F17, F18, F21, F25–F29, F37, F40, F57, F58	23
Security-critical	R1	F02, F03, F19, F20, F22, F41, F42, F43, F53–F56, F59, F60	14
Operational	R1.1	F05, F30, F32, F34, F36, F39, F52, F61	8
Advanced	P2, P3	F15, F16, F23, F24, F31, F33, F35, F38, F44, F45, F47–F49, F51	14
Optional	P3	F46	1

Release 1.1 feature	Interim practice in Release 1
F05 Verification badge	Broker verifies identity during qualification and notes it
F30 Analytics	Pipeline board shows counts per stage
F32 Valuation lead	Broker creates the lead by hand
F34 Shortlist	Broker filters qualified buyers in the CRM

Release 1.1 feature	Interim practice in Release 1
F36 Offer record	Offer written as a deal note
F39 KPI dashboard	Admin queues suffice for a pilot
F52 Favourites	Buyers use Express interest
F61 Lead import	Manual entry; moves into M2 if B11 confirms an existing pipeline

Critical dependency chain: F59 encryption → F06 sale request → F11 moderation → F12 tiered listings → F17 NDA → F18 grants → F22 signed downloads.

Optional infrastructure (not required for Release 1): dedicated search engine (MongoDB indexes meet the target); Kubernetes; SIEM; multi-region DR; MongoDB Queryable Encryption (alternative to application encryption). Recommended before public launch but optional for a staff-led pilot: WAF and CDN. Phase 2 option: per-buyer PDF watermarking.

Definition of done, Release 1

1. A seller in an enabled specialty and market submits a practice; a manager approves it; a verified buyer sees only the anonymised view.
2. A qualified buyer requests access, accepts the current NDA and is approved; only then are identity and financials visible; every view and download is logged and sealed.
3. A broker moves a deal through every stage with gate checklists and tasks.
4. Every staff account uses MFA; suspending a user ends access on the next request.
5. All Release 1 acceptance criteria pass, including the generated authorisation matrix.
6. Restore and key-access drills done once; counsel has approved the NDA, privacy notice and terms.

15. Screens and UI/UX

The MVP needs 48 screens (v1's 40 plus 8 for security, privacy and configuration). Loading, error, success and responsive behaviour are global patterns; each screen row adds only what is specific to it.

State	Behaviour
Loading	Skeletons matching the layout; buttons show an inline spinner and disable while saving

State	Behaviour
Error	Inline banner with plain message and Retry; field errors under the field with `aria-describedby`; 401 → login; 403 → no-access page with a way back
Success	4-second toast for quick actions; confirmation page for irreversible actions (submitted, NDA accepted)
Responsive	Desktop ≥1280 px: sidebar + content. Tablet 768–1279 px: collapsible sidebar, single-column grids. Mobile <768 px: bottom bar with three shortcuts; tables become cards; Kanban becomes a stage selector

15.1 Screen inventory

ID	Screen	Role	Purpose and key actions	Release
S01	Landing	Visitor	Value proposition, up to 6 Tier 0 teasers, sign-up	R1
S02	Register	Visitor	Form with role and privacy-notice consent	R1
S03	Login	Visitor	Email and password; lockout message	R1
S04	Verify email	Visitor	Link outcome; resend	R1
S05	Forgot and reset password	Visitor	Request link; set password	R1
S06	Seller onboarding wizard	Seller	About you, practice and specialty, confidentiality	R1
S07	Buyer onboarding wizard	Buyer	Buyer type, specialties and preferences, budget	R1
S08	Profile and organisation	All external	Personal, professional (per specialty) and organisation details	R1
S09	Verification submission	Seller, Buyer	Upload proof; status	R1.1

ID	Screen	Role	Purpose and key actions	Release
S10	Seller dashboard	Seller	Sale status, checklist progress, access requests	R1
S11	Sale request form	Seller	Common fields + specialty section rendered from the registry	R1
S12	Financial intake	Seller	Three-year table in market currency; attachments	R1
S13	Documents	Seller	Checklist by category, versions, review status	R1
S14	Listing preview	Seller	What each tier will see	R1
S15	Access requests	Seller	Anonymised requesters, veto, access history	R1
S16	Notifications drawer	All	Unread count, grouped by day, deep links	R1
S17	Buyer dashboard	Buyer	Profile completeness, recent listings, request statuses	R1
S18	Listing search	Buyer	Filters (specialty, city, size, band), results, pagination	R1
S19	Listing detail	Buyer	Tiered fields with locked placeholders; interest and access buttons	R1
S20	Favourites	Buyer	Saved listings	R1.1
S21	My requests	Buyer	Interests and access requests	R1
S22	NDA acceptance	Buyer	NDA text, version, checkbox, typed name	R1
S23	Broker dashboard	Broker, Manager	Today's tasks, overdue, deals by stage, new leads	R1
S24	Leads	Broker, Manager	Filterable table; assign; bulk assign	R1
S25	Lead, seller or buyer detail	Broker, Manager	Timeline, notes, tasks, qualify	R1

ID	Screen	Role	Purpose and key actions	Release
S26	Practice detail	Broker, Manager	All fields, documents, listing status	R1
S27	Pipeline	Broker, Manager	Kanban by stage; drag; filters	R1
S28	Deal workspace	Broker, Manager	Gate checklist, parties, documents, activity, offers (R1.1)	R1
S29	Data room	Broker, Manager, grantees	Document tree, review status, access log	R1
S30	Tasks and calendar	Broker	List and calendar	R1
S31	Buyer shortlist	Broker	Add or remove qualified buyers	R1.1
S32	Analytics	Broker, Manager	Deals per stage, days per stage	R1.1
S33	Admin dashboard	SA, PA	KPIs and queues	R1.1
S34	Listing moderation	SA, PA, BM	Queue with diff and reasons	R1
S35	Verification queue	SA, PA	Approve or reject proofs	R1.1
S36	User management	SA, PA	Invite, suspend, reset MFA, revoke sessions	R1
S37	NDA templates	SA, PA	Versions, approval flag	R1
S38	Pipeline configuration	SA, BM	Stages, order, gates	R1
S39	Audit log	SA, PA, BM	Search, filter, export, chain status	R1
S40	Not found, no access, maintenance	All	Message and way back	R1
S41	MFA enrolment and challenge	Staff	QR code, verify, recovery codes	R1
S42	Active sessions	All	Devices, revoke one or all	R1
S43	Invite acceptance	Staff	Set password, enrol MFA	R1
S44	Privacy centre	All external	Notice, consents, data requests	R1

ID	Screen	Role	Purpose and key actions	Release
S45	Privacy requests queue	SA, PA	Decide requests with reasons	R1
S46	Specialty and market settings	SA	Enable specialties; market values	R1
S47	Break-glass	SA	Start with reason and MFA; active banner; history	R1
S48	Lead import	BM	Upload CSV, review errors	R1.1

15.2 UI/UX guidelines

Positioning: discreet, expert, fair; plain copy; every screen that shows sensitive data says who can see it. Visual choices are proposals to validate with a short usability test.

- **Show who can see this:** a lock icon and "Visible to: you and your broker" on restricted field groups.
- **Locked fields** show "Available after NDA", never blank space.
- Sellers get spacious guided screens; brokers get dense tables and keyboard shortcuts.
- Specialty sections use the registry's labels ("Chairs", "Exam rooms", "Consultation rooms"), so one form serves all specialties.
- Numbers are never decorative.

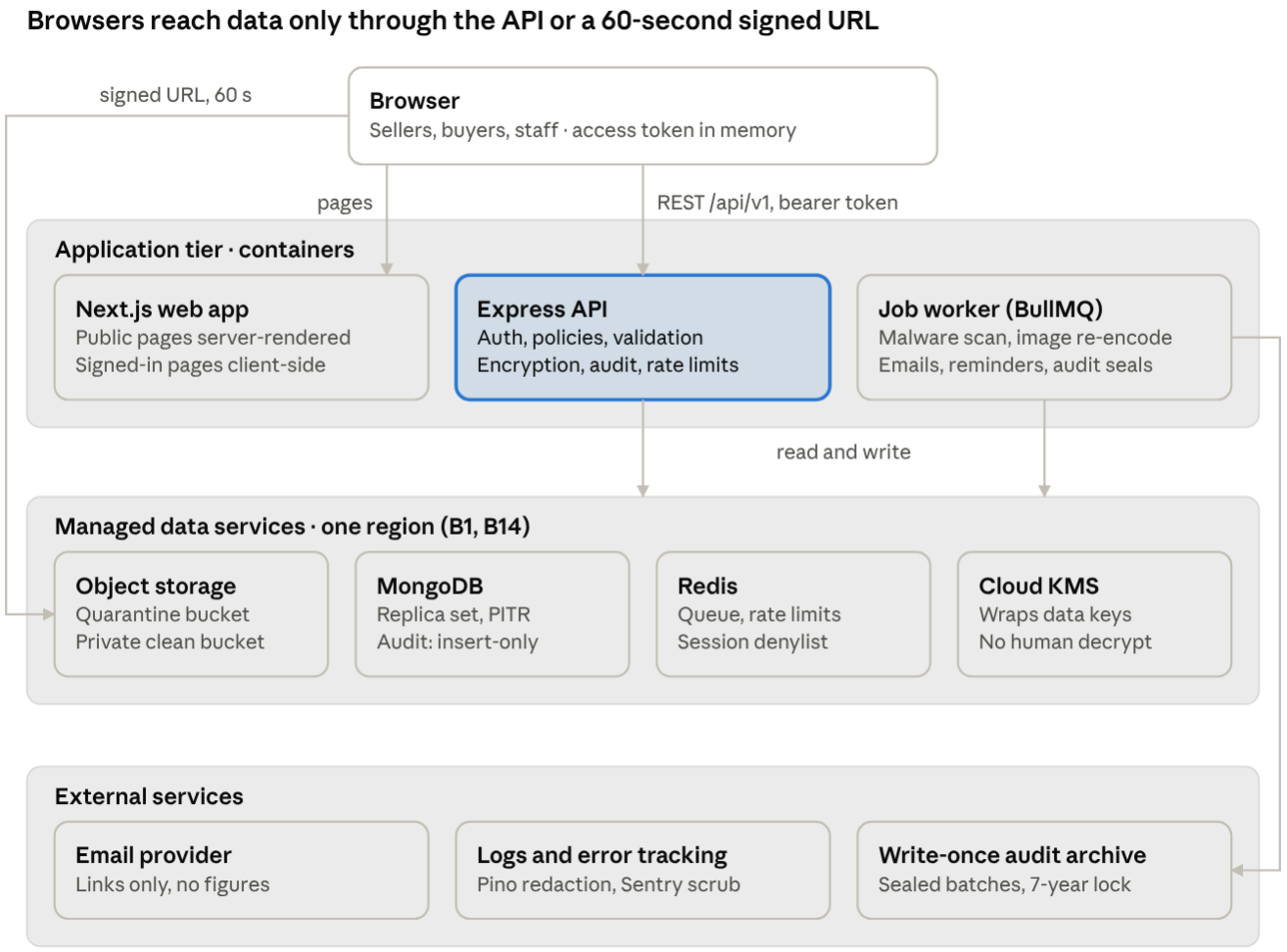
Token	Hex	Use
Primary	#0F4C5C	Buttons, links, active navigation
Primary hover	#0B3A47	Hover, pressed
Ink	#1B2430	Body and headings
Muted text	#5B6573	Secondary text (5.9:1 on white)
Surface	#F7F8FA	Page background
Border	#E1E5EB	Dividers, inputs
Success	#1F7A4D	Verified, approved
Warning text	#8A5A00	Pending, expiring
Danger	#B42318	Errors, revoked

Token	Hex	Use
Info	#2457A6	Notices

Status is always icon plus word, never colour alone. **Typography:** Inter, self-hosted via Next.js fonts; scale 12, 14 (default), 16, 18, 20, 24, 30, 36 px; line height 1.5 body, 1.25 headings; Noto Sans Devanagari reserved for a Hindi release. **Spacing:** 4 px base; radius 8 px cards, 6 px inputs; one elevation level. **Components:** Tailwind with Radix UI primitives (the layer under shadcn/ui): inputs with currency formatting from market config, combobox, multi-step form, uploader; table, status pill, Kanban card, timeline, locked-field placeholder; toast, banner, skeleton, empty state, confirm dialog; sidebar, tabs, stepper, pagination; modal, drawer, tooltip. **Accessibility:** WCAG 2.1 AA; keyboard operation; 2 px focus ring; error summary focused on submit; 44 px touch targets.

16. System architecture

A Next.js web app talks to a separate Express API over HTTPS; MongoDB holds data, private object storage holds files, a BullMQ worker runs background jobs, and a cloud KMS protects encryption keys. Next.js API routes are not used.



system architecture · application, data and external tiers

The API is the only component that reads confidential data; browsers fetch files directly from storage only with a signed URL the API issued after a permission check. The worker sends email, error reports and audit seals to external services.

Component	Responsibility	Technology
Web app	Pages, forms, role dashboards; no business rules or secrets	Next.js (App Router), React, TypeScript, Tailwind, Radix UI
API	Authentication, authorisation, validation, business rules, encryption, audit	Node.js, Express.js, TypeScript
Database	All structured data	MongoDB replica set with Mongoose
Object storage	Quarantine bucket (unscanned), clean bucket (released), archive bucket with object lock	S3-compatible, in the confirmed region

Component	Responsibility	Technology
Job worker	Malware scan, image sanitising, email, reminders, grant expiry, audit sealing	BullMQ on Redis; second entry point of the API codebase
Malware scanner	Scans uploads before release	ClamAV (`clamd`) container, signatures hourly
Key management	Wraps data-encryption keys; no human decrypt in production	AWS KMS, Google Cloud KMS, Azure Key Vault or Vault Transit (per B14)
Email	Transactional email	Provider to be selected (SES is one option)
Observability	Logs, errors, uptime	Pino with redaction, Sentry, uptime monitor

Supporting tool	Why it earns its place
Zod (shared package)	One schema validates the form and the request
React Hook Form	Long multi-step forms
TanStack Query	Caching, retries, loading and error states
bcrypt (cost 12)	Password hashing
Helmet, express-rate-limit with Redis store, cors	Headers, limits across instances, strict origins
Private storage instead of Cloudinary	Confidential files need private buckets, signed URLs and access logs
sharp	Re-encode images and strip location metadata
otplib	TOTP MFA
migrate-mongo	Versioned indexes, roles and data migrations
Vitest, Supertest, Playwright, MongoDB Memory Server, k6	Unit, API, browser, database and load tests

Confidential download flow: (1) the browser calls the API with its access token; (2) the API checks role, ownership or assignment and an active grant; (3) it writes an audit entry and requests a 60-second signed URL; (4) the browser downloads directly from storage.

Domains and environments: web at `app.<domain>`, API at `api.<domain>` (same registrable domain so the `SameSite=Strict` cookie works). Local (Docker Compose), staging and production each have their own database, buckets, KMS key, secrets and email domain; production data is never copied to staging. One region in the confirmed market; backups stay in the same jurisdiction.

17. Multi-specialty data model and database schema

One `practices` collection serves every specialty: common fields at the top level, specialty fields in a typed `specialtyAttributes` sub-document selected by `specialtyKey`. Mongoose discriminators keep each specialty strict; a Zod discriminated union in `packages/shared` validates the same shape in browser and API. Adding a field is a code change with a migration; there is no admin form builder. The MVP has 34 collections. All documents carry `createdAt`, `updatedAt` and a version key; user-deletable records are soft-deleted with `deletedAt`.

17.1 Common practice fields

Field	Type	Visible from tier
`specialtyKey`	`dental` | `veterinary` | `medical_specialist` (enabled for the market)	0
`subSpecialties[]`	From the registry	0
`marketKey`, `brokerageId`, `ownerId`, `brokerId`	References	Staff
`legalName`, `tradingName`	Encrypted + blind index	2
`registrations[]`	`{ bodyKey, number (encrypted), jurisdiction, expiresOn }`	2
`address`	`{ line*, postalCode*, city, zone, adminRegion, countryCode }`, * encrypted	City, zone 0; full 2
`clinicalUnits`	Integer: chairs, exam rooms or consultation rooms	0
`practitioners`, `staffCounts`, `yearsInOperation`, `locationsCount`	Integers	1

Field	Type	Visible from tier
`premises`	`{ tenure, leaseEndYear }`	2
`transition`	`{ type*, timeline, sellerStaysOn }`	Type 0; rest 1
`equipmentSummary`	Text, 1,000 characters, non-identifying	1
`activeVolumeBand`	Aggregate patients or client households; never a list	1
`confidentiality`	`{ showAskingPrice, allowPhotosAfterNda }`	Staff
`status`, `statusHistory[]`, `schemaVersion`	Intake lifecycle; migration version	Staff and owner

17.2 Specialty-specific fields (`specialtyAttributes`)

Field	Dental	Veterinary	Specialist medical	Tier
Label of `clinicalUnits`	Chairs	Exam rooms	Consultation rooms	0
Focus	Sub-specialties offered	`speciesFocus[]`: companion, large animal, mixed, equine, exotic	Specialty: dermatology, ophthalmology, ENT, orthopaedics, others	0
Procedure capacity	–	`surgeryTheatres`	`procedureRooms`, `dayCareBeds`	1
In-patient capacity	–	`inpatientCapacity`	–	1
Imaging, diagnostics	`imaging`: IOPA, OPG, CBCT	`diagnostics`: X-ray, ultrasound, lab	`diagnosticEquipment[]`	1
Laboratory	`inHouseLab`: none, partial, full	(in diagnostics)	(in equipment)	1
Ancillary services	–	Pharmacy, grooming, boarding	Pharmacy, physiotherapy	1

Field	Dental	Veterinary	Specialist medical	Tier
Visiting specialists	Count	–	Count	1
Referral dependency	–	–	Low, medium, high	2
Insurance or panel share %	–	–	Yes	2
Ambulatory or farm work %	–	Yes	–	2
Revenue mix %	General, specialist, implants and orthodontics	Clinical, pharmacy, grooming and boarding	Consultation, procedures, diagnostics, pharmacy	2
Extra document categories	Radiation equipment registration	Pharmacy or drug licence	Radiation and ultrasound registrations, pharmacy licence	3
Registration bodies (India examples; counsel to confirm)	State Dental Council; clinical establishment registration where applicable	State Veterinary Council	State Medical Council or NMC; clinical establishment registration	2

```
// packages/shared/specialties/veterinary.ts (abridged)
export const veterinary = defineSpecialty({
  key: 'veterinary', label: 'Veterinary clinic', clinicalUnitLabel: 'Exam
rooms',
  subSpecialties: ['companion', 'large_animal', 'mixed', 'equine', 'exotic'],
  attributes: z.object({ speciesFocus: z.array(...), surgeryTheatres:
z.number().int().min(0), ... }),
  tierOf: { speciesFocus: 0, surgeryTheatres: 1, ambulatorySharePct: 2,
revenueMix: 2 },
  extraDocumentCategories: ['pharmacy_licence'],
});
```

17.3 Collections

Collection	Purpose and key fields (* required)	Indexes	Access
`users`	email*, passwordHash*, role*, status*, name*, mobile, orgId, professional[] {specialtyKey, bodyKey, number (enc)}, emailVerifiedAt, mfa {secret (enc), enrolledAt, recoveryHashes[]}, failedLogins, lockedUntil, notificationPrefs	unique email; role+status	Owner; admins (basic fields)
`organizations`	name*, type* (brokerage, buyer_group, practice_group), taxId, verifiedAt	type+name	Members; admins
`sellerProfiles`	userId* unique, exitTimeline, defaultConfidentiality	userId	Owner; brokers
`buyerProfiles`	userId* unique, buyerType*, specialtyKeys[], marketKeys[], cities[], budget {min,max} (enc), sizePreference, transitionTypes[], financingStatus, qualification {status, by, at, note}	specialtyKeys; cities; qualification.status	Owner; brokers
`practices`	Common fields (17.1) + specialtyAttributes	ownerId; brokerageId+brokerId+status; marketKey+specialtyKey+address.city+status; legalName.bidx	Owner; assigned broker; managers
`practiceFinancials`	practiceId*, fiscalYear*, currency*, revenue*, expenses*, ebitda, askingPrice (all enc, minor units), revenueBand, source	unique practiceId+fiscalYear	Owner; broker; Tier 2 grant
`listings`	practiceId* unique, publicId* unique, specialtyKey*, marketKey*, publicTitle*, teaser {city, zone, revenueBand, clinicalUnits, clinicalUnitLabel, transitionType}, tier1 {…}, status*, approvedBy, publishedAt	status+marketKey+specialtyKey+teaser.city+publishedAt; text on publicTitle	Verified users (Tier 0–1)
`leads`	brokerageId*, type* (seller, buyer, valuation_request, manual), source*, specialtyKey, contact {name, email, phone}, userId, assignedTo, status*, nextFollowUpAt	brokerageId+assignedTo+status; nextFollowUpAt	Brokers; managers
`buyerInterests`	buyerId*, listingId*, status*, brokerNote	unique buyerId+listingId	Buyer own; broker

Collection	Purpose and key fields (* required)	Indexes	Access
`accessRequests`	buyerId*, listingId*, status*, ndaAcceptanceId, sellerVeto {at, reason}, decidedBy, decidedAt	buyerId+listingId; listingId+status	Buyer own; broker; seller (anonymised)
`ndaTemplates`	version*, marketKey*, title*, bodyHash*, storageKey*, approvedByLegalAt, active	unique marketKey+version	Admins write; brokers read
`ndaAcceptances`	userId*, templateId*, version*, bodyHash*, typedName*, acceptedAt*, ip*, userAgent	userId+templateId	Admins; broker
`accessGrants`	accessRequestId*, buyerId*, listingId*, tier*, categories[], status*, grantedBy*, expiresAt*, revokedAt, revokedReason	buyerId+listingId; expiresAt	Brokers; buyer own
`documents`	publicId* unique, subjectType* (practice, deal, buyer_qualification, verification), subjectId*, category*, title*, current {v, storageKey, mime, sizeBytes, sha256}, versions[], scanStatus*, reviewStatus*, expiresOn	subjectType+subjectId+category; reviewStatus	Owner; brokers; grants
`deals`	brokerageId*, practiceId*, sellerId*, buyerId, brokerId*, stageId*, stageHistory[], checklistState, status*, fee {amount (enc), status}	brokerageId+brokerId+stageId; practiceId	Assigned broker; managers; seller sees stage
`pipelineStages`	brokerageId*, name*, order*, gate*, checklist[], active	brokerageId+order	Managers write
`tasks`	brokerageId*, title*, assigneeId*, dueAt*, status*, leadId, dealId	assigneeId+status+dueAt	Assignee; managers
`activities`	brokerageId*, entityType*, entityId*, kind*, body, authorId*, visibility*	entityType+entityId+createdAt	Brokers; managers
`offers` (R1.1)	dealId*, parentId, amount* (enc), structure, conditions, expiresAt, recordedBy* (immutable)	dealId+createdAt	Brokers; managers
`favourites` (R1.1)	buyerId*, listingId*	unique buyerId+listingId	Buyer own
`shortlists` (R1.1)	listingId* unique, entries[] {buyerId, addedBy, reason}	listingId	Brokers
`notifications`	userId*, type*, payload (no confidential values), readAt	userId+readAt+createdAt; TTL 180 days	Owner
`sessions`	userId*, familyId*, userAgent, ipPrefix, createdAt, lastUsedAt, revokedAt	userId; TTL on absolute expiry	Owner; admins

Collection	Purpose and key fields (* required)	Indexes	Access
`refreshTokens`	familyId*, tokenHash*, expiresAt*, replacedBy, revokedAt	familyId; TTL on expiresAt	Server only
`auditLogs`	seq*, actorId*, actorRole*, action*, entityType*, entityId*, ipPrefix, meta (no confidential values), at*, sealId	seq unique; at; actorId+at; entityType+entityId	Insert-only user; admins read
`auditSeals`	fromSeq*, toSeq*, hash*, prevHash*, archiveKey*, sealedAt*	toSeq	Super Admin
`breakGlassSessions`	adminId*, scope {practiceId or dealId}, *reason*, ticketRef*, startedAt*, expiresAt*, endedAt	adminId+startedAt	Admins; managers notified
`privacyNotices`	marketKey*, version*, body*, publishedAt*	unique marketKey+version	Public read
`consents`	userId*, purpose*, noticeVersion*, granted*, at*, ip	userId+purpose	Owner; admins
`dataRequests`	userId*, kind* (access, correction, deletion), status*, decision, reason, decidedBy	status+createdAt	Owner; admins
`specialtySettings`	key*, marketKey*, enabled*, enabledBy, enabledAt	unique key+marketKey	Super Admin
`marketConfigs`	key* unique, countryCode*, currency*, locale*, fiscalYearStartMonth*, regions[], cities[] {name, zones[]}, revenueBands[], registrationBodies {specialtyKey: []}, flags {externalBrokersEnabled, sellerSelfListingEnabled, directMessagingEnabled}, enabled	key	Super Admin; public read (non-sensitive)
`verificationRequests` (R1.1)	subjectId*, kind*, documents[], status*, reviewedBy	status+createdAt	Admins; subject
`leadImports` (R1.1)	brokerageId*, uploadedBy*, rows, accepted, rejected[], status	brokerageId+createdAt	Managers

Phase 2 collections: `matches`, `ddChecklists`, `messages`, `savedSearches`, `valuationConfigs` (per specialty and market), `valuationEstimates`.

Embedding versus referencing: embed bounded, read-together data (document versions, stage history, listing tiers); reference anything that grows or has its own access rule (financials, activities, tasks, audit, grants). The listing is denormalised on purpose at approval; later practice changes do not alter it until a broker re-approves.

State machines: practice (intake) Draft → Submitted → In review → Changes requested / Rejected / Approved, Withdrawn; listing (publication) Published ⇄ Paused, Published → Under offer → Sold, Withdrawn.

17.4 Example: veterinary practice and its listing (abridged)


```
{
  "practice": {
    "specialtyKey": "veterinary", "marketKey": "IN", "subSpecialties":
["companion"],
    "legalName": { "ct": "…", "iv": "…", "tag": "…", "kid": "field-2026-1" },
    "address": { "line": { "ct": "…" }, "city": "Pune", "zone": "West",
"adminRegion": "MH", "countryCode": "IN" },
    "clinicalUnits": 3, "yearsInOperation": 11,
    "specialtyAttributes": { "speciesFocus": ["companion"],
"surgeryTheatres": 1, "inpatientCapacity": 12 },
    "status": "approved", "schemaVersion": 1
  },
  "listing": {
    "publicId": "V1StGXR8_Z5jdHi6B-myT", "specialtyKey": "veterinary",
    "publicTitle": "Companion-animal clinic, West Pune",
    "teaser": { "city": "Pune", "zone": "West", "clinicalUnits": 3,
"clinicalUnitLabel": "Exam rooms", "revenueBand": "50L-1Cr",
"transitionType": "complete_sale" },
    "tier1": { "surgeryTheatres": 1, "inpatientCapacity": 12,
"practitioners": { "fullTime": 2 } },
    "status": "published"
  }
}
```


The city is illustrative; launch cities are open (B3).

18. API specification

The Express API is versioned under `/api/v1`, speaks JSON, and authorises every route. The MVP has 131 endpoints (114 in Release 1, 17 in Release 1.1); each belongs to exactly one feature. F03, F42 and F59 are cross-cutting and own no route.

18.1 Conventions

Topic	Rule
Authentication	Access token in `Authorization: Bearer`; rotating refresh token in an httpOnly, Secure, `SameSite=Strict` cookie scoped to `/api/v1/auth`; refresh and logout need a custom CSRF header and matching `Origin`
Success envelope	`{ "success": true, "data": …, "meta": { … } }`
Error envelope	`{ "success": false, "error": { "code": "VALIDATION_FAILED", "message": "…", "details": [{ "field": "email", "issue": "…" }] }, "requestId": "…" }`
IDs in URLs	Listings and documents use random 21-character `publicId`; internal ObjectIds never appear in public URLs
Pagination	`page` (default 1), `pageSize` (default 20, max 100); `meta` returns page, pageSize, total, totalPages
Sorting	`sort=field:asc
Filtering	Plain query parameters; repeated values mean OR
Validation	Zod schema per route; unknown body fields rejected; keys starting with `$` or containing `.` rejected
Idempotency	`Idempotency-Key` on POSTs that create interests, access requests, offers and imports
Concurrency	`If-Match` version on deal, practice and listing updates; stale → 409
Rate limits (proposed)	Auth 10/min/IP; login lockout after 5 failures in 15 min per account+IP; 300/min/user; uploads 20/h; access requests 20/day; listing details 120/h; 429 with `Retry-After`
Handler order	Authenticate → authorise by role → check ownership, assignment or grant → validate → service → audit → respond; 404 where 403 would reveal a record

18.2 Critical endpoints

Endpoint	Roles	Request	Success	Errors
POST /auth/register	Public	name, email, mobile, password, role (seller or buyer), consent	202, same response whether or not the email exists	400 invalid role; 422 weak password
POST /auth/login	Public	email, password	200 accessToken, user; refresh cookie; `mfaRequired` for staff	401 invalid (same for unknown email); 423 locked; 403 email not verified
POST /auth/mfa/challenge	Staff after password	code or recovery code	200 accessToken with `mfa=true`	401 invalid code
POST /auth/refresh	Cookie	Refresh cookie + CSRF header	200 new access token, rotated cookie	401 invalid or reused (family revoked); 401 user denylisted
POST /practices	Seller, Broker	Common fields + specialtyAttributes for an enabled specialty; saved as draft	201 practice	400 unknown field; 422 specialty not enabled
POST /practices/:id/submit	Seller (owner)	Empty	200 Submitted; lead created	422 missing fields listed; 404 not owner; 409 already submitted
GET /listings	Verified buyer, staff	q, specialty, city, revenueBand, clinicalUnits, transitionType, sort, page	200 Tier 0–1 cards	400 bad sort; 403 email unverified
GET /listings/:publicId	Verified buyer, staff	–	200 fields allowed by caller's tier + `lockedFields[]`	404 if not published

Endpoint	Roles	Request	Success	Errors
POST /listings/:publicId/access-requests	Qualified buyer	message?	201 request with status NDA pending	422 not qualified; 409 duplicate
POST /nda/accept	Buyer	templateVersion, accessRequestId, typedName	201 acceptance (hash, time, IP)	409 outdated version; 422 name mismatch
POST /access-requests/:id/approve	Assigned broker, manager	tier, categories[], expiresAt	200 grant	404 not assigned; 422 NDA not accepted or seller veto; 400 expiry in past
POST /documents/uploads	Seller, broker, buyer (own qualification)	subjectType, subjectId, category, fileName, mime, sizeBytes, documentId?	201 documentId, presigned POST (10 min)	400 type; 413 over 25 MB; 429
GET /documents/:publicId/download-url	Owner, broker, grant holder	–	200 url, expiresIn 60; audit entry	404 no grant or unknown; 409 not scanned clean
PATCH /deals/:id/stage	Assigned broker, manager	stageId, reason?, If-Match	200 deal with stage history	422 gate incomplete (items listed); 422 backward without reason; 409 stale
POST /admin/break-glass	Super Admin with recent MFA	scope, reason, ticketRef	201 session, expires in 60 min; manager notified	422 missing reason; 403 MFA step-up needed

18.3 Endpoint inventory (131)

Roles: Pub public · Any signed-in · SE seller · BU buyer · BR assigned broker · BM manager · AD admin · SA super admin.

Module	Endpoints (roles)	Features
Auth (9)	POST /auth/register (Pub); POST /auth/verify-email (Pub); POST /auth/resend-verification (Pub); POST /auth/login (Pub); POST /auth/refresh (cookie); POST /auth/logout (Any); POST /auth/forgot-password (Pub); POST /auth/reset-password (Pub); GET /auth/me (Any)	F01, F02
MFA (5)	POST /auth/mfa/enroll; POST /auth/mfa/verify-enrollment; POST /auth/mfa/challenge; POST /auth/mfa/recovery-codes (staff); DELETE /admin/users/:id/mfa (AD)	F53
Sessions (4)	GET /auth/sessions; DELETE /auth/sessions/:id; POST /auth/sessions/revoke-all (Any); POST /admin/users/:id/revoke-sessions (AD)	F54
Users and profiles (9)	GET, PATCH /users/me; POST /organizations; GET, PATCH /organizations/:id; GET, PUT /profiles/seller/me (SE); GET, PUT /profiles/buyer/me (BU)	F04 (7), F09 (2)
Privacy (7)	GET /privacy/notice/current (Pub); POST /privacy/consents; GET /privacy/consents/me; POST /privacy/requests; GET /privacy/requests/me (Any); GET /admin/privacy/requests; PATCH /admin/privacy/requests/:id (AD)	F56
Configuration (3)	GET /config/specialties (Pub); PATCH /admin/config/specialties/:key (SA); GET /config/market (Pub)	F57 (2), F58 (1)

Module	Endpoints (roles)	Features
Verification (4)	POST /verification-requests; GET /verification-requests/me (SE, BU); GET /admin/verification-requests; PATCH /admin/verification-requests/:id (AD)	F05
Practices (8)	POST /practices (SE, BR); GET /practices; GET, PATCH /practices/:id; POST /practices/:id/submit (SE); POST /practices/:id/withdraw (SE, BM); PUT /practices/:id/financials/:fiscalYear (SE, BR); GET /practices/:id/financials (owner, BR, BM, grant)	F06 (6), F07 (2); F08 via PATCH
Buyers (2)	PATCH /buyers/:id/qualification; GET /buyers (BR, BM)	F10
Listings (5)	GET /public/teasers (Pub); GET /listings/:publicId; GET /listings; GET /admin/listings/queue (BM, AD); POST /admin/listings/:practiceId/decision (BM, AD)	F12 (2), F13 (1), F11 (2)
Interests (4)	POST /listings/:publicId/interests; GET /interests/me; DELETE /interests/:id (BU); GET /broker/interests (BR, BM)	F14
Favourites (3)	POST, DELETE /listings/:publicId/favourite; GET /favourites (BU)	F52
NDA (5)	GET /nda/templates/current (BU); POST /nda/accept (BU); GET, POST /admin/nda-templates; PATCH /admin/nda-templates/:id (AD)	F17
Access (7)	POST /listings/:publicId/access-requests (BU); GET /access-requests (scoped); POST /access-requests/:id/approve; POST /access-requests/:id/reject (BR, BM); POST /access-requests/:id/veto (SE); GET /access-grants (scoped); POST /access-grants/:id/revoke (BR, BM, SE)	F18

Module	Endpoints (roles)	Features
Documents (9)	POST /documents/uploads; POST /documents/:publicId/complete; GET /documents; GET /documents/:publicId; PATCH /documents/:publicId/review (BR, BM); DELETE /documents/:publicId; GET /documents/:publicId/download-url; GET /documents/:publicId/access-log; GET /practices/:id/access-log (owner, BR, BM)	F20 (2), F21 (4), F22 (1), F19 (2)
CRM (14)	POST, GET /leads; GET, PATCH /leads/:id; POST /leads/:id/convert; POST /leads/:id/assign (BM); POST, GET /tasks; PATCH /tasks/:id; POST /activities; GET /activities; POST /valuation-requests (Pub, SE); POST /leads/import; GET /leads/import/:id (BM)	F25 (5), F26 (1), F27 (3), F28 (2), F32 (1), F61 (2)
Deals and pipeline (14)	POST, GET /deals; GET, PATCH /deals/:id; PATCH /deals/:id/stage; POST /deals/:id/assign (BM); GET /deals/:id/timeline; GET /pipeline/stages; POST /admin/pipeline/stages; PATCH /admin/pipeline/stages/:id (BM, AD); POST, GET /deals/:id/offers; GET, PUT /listings/:publicId/shortlist (BR, BM)	F29 (9), F26 (1), F36 (2), F34 (2)
Notifications (4)	GET /notifications; PATCH /notifications/:id/read; POST /notifications/read-all; PUT /notifications/preferences (Any)	F37
Admin (13)	GET /admin/dashboard; GET /admin/users; POST /admin/users/invite; PATCH /admin/users/:id; POST /auth/accept-invite (Pub with token); GET /admin/audit-logs; GET /admin/audit-logs/export; GET /admin/audit-logs/verify (SA); POST /admin/break-glass; POST /admin/break-glass/:id/end; GET /admin/break-glass (SA); GET /analytics/broker (BR); GET /analytics/brokerage (BM)	F39 (1), F40 (4), F41 (2), F60 (1), F55 (3), F30 (2)
Platform (2)	GET /health (Pub, no data); GET /ready (internal)	F43

Count check: 9 + 5 + 4 + 9 + 7 + 3 + 4 + 8 + 2 + 5 + 4 + 3 + 5 + 7 + 9 + 14 + 14 + 4 + 13 + 2 = 131.

19. Security architecture

The platform holds owners' identities, financial statements and negotiation positions, so the design assumes an attacker wants to identify an anonymous practice or read a data room. The baseline is OWASP ASVS Level 2; values marked "proposed" are for management and counsel to confirm.

19.1 Top threats and controls

Threat	Control
Buyer guesses IDs and reads another deal's records	Policy checks on every route; random public IDs; 404 for hidden records; generated wrong-user tests on every route
Anonymous listing re-identified	Revenue bands; zone not locality; no photos or opening year at Tier 0; image metadata stripped; broker identifiability review; view rate limits and scrape alerts
Stolen or shared document link	60-second signed URLs after a permission check; one audit entry per issue; URLs never logged or emailed
Malicious upload	Allow-list, magic-byte check, 25 MB limit, ClamAV scan before release, files served as attachments from the storage domain
Account takeover	bcrypt; lockout; rotating refresh tokens with reuse detection; mandatory staff MFA; uniform responses to prevent enumeration
Insider misuse	No standing admin access to confidential data; break-glass with reason, MFA and notification; sealed audit log
Injection and XSS	Zod strict schemas, operator-key rejection, Mongoose `strictQuery`, React output encoding, strict Content-Security-Policy
Denial of service and brute force	Redis-backed rate limits, body limits, timeouts; optional WAF

Threat	Control
Database or backup leak	Field-level encryption with KMS-held keys, so leaked data has no readable financials or identities

19.2 Encryption key management (F59)

- Envelope encryption: a KMS key per environment wraps data-encryption keys (DEKs); a second KMS key wraps the blind-index HMAC key.
- One crypto service is the only code that encrypts or decrypts: AES-256-GCM via Node `crypto`, random 96-bit IV, additional authenticated data `collection|_id|field` so ciphertext cannot be moved between records. Stored as `{ ct, iv, tag, kid, v }`.
- DEKs cached in memory for at most 15 minutes (proposed); never on disk, in logs or Redis.
- Yearly rotation; new DEK versions; lazy re-encryption job; no downtime.
- Only API and worker service identities may decrypt in production; humans only via cloud break-glass with two-person approval. KMS keys have maximum deletion protection.
- Not used: Mongoose getters that auto-decrypt (they leak via `toJSON`). MongoDB Queryable Encryption is an acceptable alternative if hosting supports it.

19.3 Sensitive financial data

Data	Protection
Revenue, expenses, EBITDA, asking price, offers, fees, buyer budget	Encrypted; integer minor units + currency; decrypted only after a policy check
Practice names, registration numbers, address line, postal code, MFA secrets	Encrypted; names and registration numbers also get an HMAC blind index for duplicate checks
Revenue band, city, zone, clinical units	Plain text for search; derived at write time
Bank and card numbers	Never stored

Confidential figures never appear in logs, emails, notifications, analytics or error reports.

19.4 Backup and recovery

Managed replica set with point-in-time recovery; daily snapshots kept 30 days; recovery point 1 hour, recovery time 4 hours (proposed). Backups use a separate key, stay in the same jurisdiction and are unreachable by application credentials; encrypted fields stay encrypted inside them. Clean-bucket versioning keeps deleted objects 30 days. Quarterly restore drill into an isolated environment, including a KMS decrypt test. A deletion request completes when the record is removed and backups containing it have expired (30 days); the privacy notice says so.

19.5 Access revocation

Event	Effect	Mechanism
Grant revoked or expired	Next request refused	Grants checked per request; no cached decisions
User suspended, role changed, password reset	All access ends on the next request	Revoke every refresh family; Redis denylist of the user for 15 minutes checked by auth middleware
Broker reassigned	Old broker loses access immediately	Assignment checked per request
Listing withdrawn or deal lost	All grants revoked	Service hook
Deal closed	Buyer grants expire after 30 days (proposed)	Scheduled job
Staff leaves	Suspended the same day	Offboarding checklist (Brokerage Manager)

19.6 Audit log integrity (F60, F41, F19)

- Written through a second Mongo connection whose user can only insert and find on `auditLogs`; the main API user cannot write audit data.
- Business change and audit entry share a transaction where they must agree.
- Every minute the worker seals new entries: ordered by `seq`, `hash = SHA-256(canonical entry + previous hash)`, batch hash stored in `auditSeals`, batch written to an object-lock archive (compliance mode, 7 years proposed).
- `GET /admin/audit-logs/verify` recomputes the chain; any change raises an alert.

- Events: logins, MFA and session changes, role changes, listing decisions, NDA acceptances, grants, vetoes, revocations, every view or download of confidential data, break-glass, configuration changes, consents and data-rights decisions, exports, key rotations.

19.7 File scanning (F20)

1. Presigned POST to the quarantine bucket fixes key, type and size (25 MB).
2. `POST /documents/:publicId/complete` queues a scan; nothing is downloadable until clean.
3. Magic-byte check against PDF, DOCX, XLSX, JPG, PNG; macro-enabled Office files, password-protected PDFs and unscannable archives rejected.
4. ClamAV scan; signatures hourly; fail closed if `clamd` is down or signatures older than 24 hours.
5. Images re-encoded with metadata (including GPS) removed.
6. Clean files copied to the private bucket under a random key; rejected files deleted, audited, uploader and security contact notified.
7. Served as `Content-Disposition: attachment` from the storage domain only.

Uploads containing patient or client names (for example appointment exports) are rejected at broker review; upload guidance says so.

19.8 Signed URLs (F22)

Downloads: 60 seconds, one object, fixed response headers. Uploads: 10 minutes, one key, size-limited. A URL works for anyone holding it until expiry, so URLs are never logged (query strings stripped), emailed or stored. Object keys are random UUIDs; public access blocked; bucket CORS allows only the web origin.

19.9 Sessions and MFA (F02, F53, F54)

Setting	Value
Access token	Asymmetric JWT (EdDSA or RS256) with `kid`; 15 minutes; claims `sub`, `role`, `sid`, `mfa`; held in memory, never `localStorage`
Refresh token	Opaque, stored hashed; rotates on use; reuse revokes the family
External users	7 days idle, 30 days absolute (proposed)
Staff	30 minutes idle, 12 hours absolute (proposed)

Setting	Value
MFA	TOTP mandatory for staff; 10 hashed single-use recovery codes; step-up within 5 minutes for break-glass, role changes and exports
Next.js	Signed-in areas client-rendered with TanStack Query; middleware only redirects cosmetically; the API decides access
User control	List sessions (device, approximate location, last use); revoke one or all

19.10 Administrator access monitoring (F55)

Break-glass needs MFA step-up, a reason and ticket reference; it covers one practice or deal for 60 minutes, shows a banner, notifies the Brokerage Manager and another Super Admin, and audits every read. Weekly report of break-glass and admin actions to management. Alerts by email or webhook: more than 50 downloads per user per hour (proposed), login from a new country, repeated 404s on listing or document IDs, audit-chain failure, stale ClamAV signatures. Super Admin identities are separate from broker accounts; no human holds direct production database credentials.

19.11 Log redaction (F43)

Pino logs an allow-list only (request ID, route template, status, duration, user ID, role); bodies never. `redact` paths as backup: authorization and cookie headers, password, token, typedName, revenue, expenses, askingPrice, legalName, address, email, mobile. Query strings removed from logged URLs. Sentry with `sendDefaultPii: false`, a `beforeSend` scrubber and no session replay on signed-in pages. Mongoose debug off outside development. A CI test runs a journey with marker values and fails if any marker appears in logs.

19.12 Rate limiting and abuse (F42)

`express-rate-limit` with a Redis store keyed by IP and user (limits in 18.1); `trust proxy` set to the exact hop count; JSON body limit 100 KB; Helmet with strict CSP; uniform responses for registration and password reset; optional CAPTCHA (Turnstile or hCaptcha) after repeated failures.

19.13 Other controls

TLS 1.2+ with HSTS; secrets in a secrets manager, separate per environment; dependency and image scanning in CI; no deploy with failing security tests; penetration test before launch.

Retention (proposed, counsel to confirm): audit logs 7 years; closed-deal documents 7 years after closing; withdrawn-listing documents 12 months; unverified accounts 30 days; notifications 180 days.

20. Privacy and legal

The platform is a data controller (a data fiduciary under India's DPDP Act) for owners, buyers and staff, so compliance is designed in from the start. These are questions for qualified counsel; nothing here is legal advice.

If India is confirmed (B1): the Digital Personal Data Protection Rules, 2025 were notified on 13 November 2025 with a phased rollout; substantive obligations (notice, consent, security safeguards, breach handling) are scheduled for 13 May 2027. v1 could not confirm whether proposed accelerations were adopted, or the status of court challenges; counsel should confirm live dates. The Rules reportedly set a 72-hour window for the detailed breach report (confirm).

Design consequences (F56): plain-language privacy notice at sign-up; purpose-specific consent records; access, correction and deletion requests; breach-response runbook; data minimisation (no national ID numbers, no patient or client data); named grievance contact.

Professional and advertising rules: the Dentists (Code of Ethics) Regulations restrict advertising by dentists; an identifying listing could be read as advertising, which supports anonymised listings and legal review before any paid featured placement (F16). Equivalent codes for medical and veterinary practitioners must be reviewed before those specialties are enabled.

Questions for counsel, per enabled specialty and market:

- Who may own a dental, veterinary or medical practice (practitioner only, or companies and investors), and does it vary by state?
- Which registrations transfer on sale and which must be re-obtained (establishment registration, biomedical waste authorisation, radiation and ultrasound equipment registration, pharmacy or drug licences, local trade licences)?
- Does introducing parties to share-based transactions require any licence; how are brokerage fees taxed (GST)?
- Is clickwrap NDA acceptance enforceable, and when is e-signature needed?

- Tax and stamp duty on asset versus share transfers and goodwill.
- Data residency requirements for the chosen region.

21. AI strategy

No AI feature is needed for the MVP: every MVP requirement is met by forms, rules and a database, and keeping AI out removes accuracy and data-protection risk at launch.

Candidate	Verdict
Listing description drafting	Phase 3 optional (F46); broker edits and approves; identifiability check after drafting
Financial document extraction	Phase 3 pilot; values shown as "suggested, unverified" until a broker confirms
Document completeness	Deterministic checklist (F24), no AI
Buyer–practice matching	Deterministic scoring (F35); learned weights only after real outcomes
Internal deal summaries, diligence question lists	Phase 3, staff only
Valuation number	Not recommended; stays a transparent formula

Rules for any AI feature: outputs labelled as suggestions and stored separately from verified facts; a person approves before anything affects a listing, offer or decision; AI never decides prices, matches or legal positions and never contacts anyone; uploaded documents are untrusted data (prompt-injection defence); confidential data only to providers with a data-processing agreement, no-training commitment and counsel-approved residency; calls logged without confidential text; each feature ships with an evaluation set and agreed accuracy target.

22. Testing strategy and acceptance criteria

Authorisation and confidentiality get the heaviest testing, because one leak of an anonymous listing or a data-room file would end trust in the product. Each acceptance criterion is at least one automated test named with its ID (for example `AC-07 grants tier 2 only after NDA and approval`); CI fails if an AC has no test.

Suite	Tooling	Covers	Gate
U Unit	Vitest	Services, policies, Zod schemas, tier redaction, crypto, audit chain	80% on services and policies
I API integration	Supertest, MongoDB Memory Server (replica set)	Every route: success, validation, wrong role, wrong owner, expired grant, rate limit	Every route has an allow and a deny test
Z Authorisation matrix	Generated from `permissions.ts`	Each role × each protected action, plus wrong-user access	Zero failures
D Database	Memory Server, staging replica set	Indexes, TTL, transactions, soft delete, insert-only audit role, migrations	CI
E End-to-end	Playwright	Definition-of-done journeys per enabled specialty	Before each release
A Accessibility, responsive	Playwright at 360/768/1280 px, axe	No horizontal scroll; keyboard paths; no serious axe issues	Before each release
S Security	Dependency audit, image scan, OWASP ZAP baseline, manual review, penetration test	Injection, XSS, CSRF on refresh, IDOR, upload abuse, headers, scraping, log leaks	Before launch and major changes
P Performance	k6	Search and listing detail at section 11 targets	Before launch

Edge cases that must have a test: withdrawn listing opened from a saved link → 404 and "unavailable"; grant expires mid-session → next download refused; two brokers move one deal → second gets 409; seller edits figures after verification → document back to Pending; buyer changes an ID in the URL or calls the API directly → 404; executable renamed `.pdf` → rejected; NDA acceptance of an old version → refused; suspended user with a live access token → 401 on next request; specialty disabled while practices exist → records remain readable by staff.

22.1 Acceptance criteria

ID	Feature	Criterion
AC-01	F01	Given a new user, when they register, then the account is unverified and a 24-hour link is emailed; after verification login succeeds; an expired or reused link returns 400
AC-02	F02	Given 5 failed logins for an account within 15 minutes, a 6th attempt (even correct) is refused for 15 minutes and audited
AC-03	F02	Given a refresh token already used, when presented again, then 401 and every token in its family is revoked
AC-04	F06	Given a draft missing three mandatory fields, submit returns 422 naming all three and status stays Draft; when complete, status becomes Submitted and a lead is created
AC-05	F11, F12	Given an approved practice, a listing document is generated with only Tier 0–1 fields; buyers find it within 5 seconds; no response contains name, address or exact financials (run per enabled specialty)
AC-06	F12, F13	Given 50 listings, a search by city and specialty with pageSize 20 returns only matches with correct `meta.total`; a non-whitelisted sort returns 400
AC-07	F10, F17, F18	Given a buyer without NDA acceptance, a Tier 2 request returns 404/422 and no grant exists; after acceptance and approval, the grant has an expiry and Tier 2 fields are returned
AC-08	F18	Given an active grant, when revoked, the buyer's next Tier 2 request returns 404 within 1 second
AC-09	F20	Given an executable renamed to PDF, the EICAR test file and a 26 MB file, each is rejected and none reaches the clean bucket; a clean 5 MB PDF becomes available only after the scan

ID	Feature	Criterion
AC-10	F19, F22	Given a document grant, a download returns a 60-second URL and writes one audit entry; the URL fails after 60 seconds; a buyer without a grant gets 404
AC-11	F29	Given an incomplete hard-gate checklist, moving the deal forward returns 422 listing items; a manager override with reason succeeds and is audited
AC-12	F03	Given the permission matrix, every disallowed call returns 403 or 404 and every allowed call succeeds, with zero exceptions
AC-13	F27	Given a task due at 10:00 not completed, it appears overdue and a reminder email is sent within 15 minutes
AC-14	F41	Given a login, listing decision, grant, revocation, download or role change, an audit entry exists that no application user can edit or delete
AC-15	F37	Given an NDA acceptance, the broker gets an in-app notification and an email within 2 minutes; the email has no figures, document names or URLs to files
AC-16	F33 (P2)	Given valuation inputs, the estimate shows a low–mid–high range, assumptions, configuration version and the not-certified statement; the same inputs reproduce the same result
AC-17	F04	Given two users, PATCH on another's profile or organisation returns 404; own updates succeed; unknown fields return 400
AC-18	F05	Given a verification request, approval by a seller or broker returns 403; admin approval sets the badge and is audited
AC-19	F07	Given saved financials, the raw database document holds only ciphertext amounts; a buyer without a Tier 2 grant gets 404; a duplicate fiscal year returns 409

ID	Feature	Criterion
AC-20	F08	Given `showAskingPrice=false`, no tier ever returns the asking price; with `true`, it appears at Tier 2 only
AC-21	F09	Given a buyer budget, it never appears to other buyers, the seller or unassigned brokers
AC-22	F10	Given an unqualified buyer, an access request returns 422 and nothing is stored; after qualification it returns 201
AC-23	F14	Given an existing interest, repeating it returns 409; a new interest notifies the assigned broker and links to the buyer's lead
AC-24	F17	Given a newer active NDA version, accepting the old version returns 409 and stores nothing
AC-25	F21	Given a verified document, a replacement creates a new version, keeps the old one and resets review to Pending
AC-26	F25	Given a sale request, buyer sign-up or valuation request, exactly one lead exists with source and specialty
AC-27	F26	Given a lead assigned to broker A, broker B gets 404; after reassignment to B, A gets 404 on the next request and the change is audited
AC-28	F28	Given an internal note, its text never appears in any seller or buyer response
AC-29	F29	Given two brokers editing a deal, the second save with a stale version returns 409
AC-30	F30	Given a 20-deal fixture, analytics counts match and contain no financial figures
AC-31	F32	Given a valuation request, a `valuation_request` lead is created and the requester sees confirmation without any estimate
AC-32	F34	Given a shortlist, adding an unqualified buyer returns 422; buyers and sellers can never read shortlists

ID	Feature	Criterion
AC-33	F36	Given a recorded offer, editing it returns 405; a revision is a new record linked to its parent
AC-34	F39	Given a fixture, each admin KPI equals the fixture count
AC-35	F40	Given an invited broker, no staff route responds until MFA is enrolled; after suspension, the next request returns 401
AC-36	F42	Given 11 auth requests from one IP in a minute, the 11th returns 429 with `Retry-After`; a body containing `$where` returns 400
AC-37	F43	Given the quarterly drill, a point-in-time restore yields readable, decryptable records and the recovery time is recorded; `/ready` reports dependency status without data
AC-38	F52	Given a favourited listing later withdrawn, it shows unavailable and its detail returns 404
AC-39	F53	Given a staff user without MFA, staff routes return 403 `MFA_REQUIRED`; a used recovery code fails on reuse
AC-40	F54	Given two sessions, revoking one makes its next refresh return 401 while the other continues; a password reset revokes all
AC-41	F55	Given break-glass without reason or MFA step-up, 422; an approved session ends after 60 minutes, notifies the manager and audits every read
AC-42	F56	Given registration, consent is stored with the notice version; a deletion request is tracked to a decision; records under legal hold are reported as retained with a reason
AC-43	F57	Given a specialty disabled for a market, new practices in it return 422, its listings leave search, and existing records stay readable by staff
AC-44	F58	Given a market configuration, bands, currency and fiscal-year labels come from it; amounts are stored as integer minor units

ID	Feature	Criterion
AC-45	F59	Given a key rotation, old values still decrypt, new writes use the new `kid`, and a ciphertext swapped between records fails authentication
AC-46	F60	Given sealed entries, modifying one directly in the database fails chain verification and raises an alert; the application user cannot update or delete audit entries
AC-47	F61	Given a CSV with valid, invalid and duplicate rows, valid rows become leads, invalid rows are reported, duplicates by email or phone are skipped, and the import is audited

23. Traceability matrix

Every MVP feature maps to its endpoints (section 18.3), acceptance criteria, test suites and one milestone (section 24).

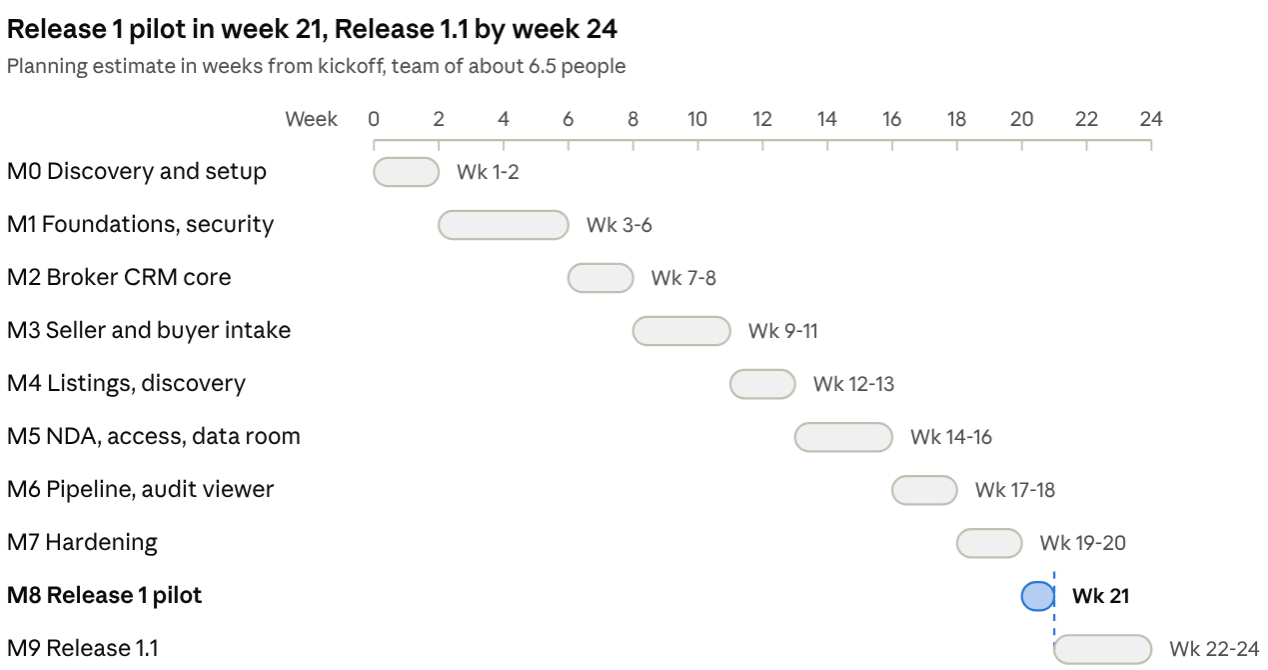
Feature	Endpoints	AC	Tests	Milestone
F01	Auth (3)	AC-01	U, I, E	M1
F02	Auth (6)	AC-02, AC-03	U, I, S	M1
F03	Cross-cutting	AC-12	U, Z	M1
F04	Users and profiles (7)	AC-17	U, I, Z, E	M3
F05	Verification (4)	AC-18	I, Z	M9
F06	Practices (6)	AC-04	U, I, Z, E	M3
F07	Practices (2)	AC-19	U, I, Z, D	M3
F08	Via PATCH /practices/:id	AC-20	U, I	M3
F09	Profiles (2)	AC-21	U, I, Z	M3
F10	Buyers (2)	AC-07, AC-22	I, Z	M3
F11	Listings (2)	AC-05	I, Z, E	M4

Feature	Endpoints	AC	Tests	Milestone
F12	Listings (2)	AC-05, AC-06	U, I, Z, S	M4
F13	Listings (1)	AC-06	I, P	M4
F14	Interests (4)	AC-23	I, Z	M4
F17	NDA (5)	AC-07, AC-24	U, I, Z	M5
F18	Access (7)	AC-07, AC-08	U, I, Z, E	M5
F19	Documents (2)	AC-10	I, Z, D	M5
F20	Documents (2)	AC-09	U, I, S	M5
F21	Documents (4)	AC-25	I, Z	M5
F22	Documents (1)	AC-10	I, Z, S	M5
F25	CRM (5)	AC-26	I, Z	M2
F26	CRM (1), deals (1, built in M6)	AC-27	I, Z	M2
F27	CRM (3)	AC-13	U, I	M2
F28	CRM (2)	AC-28	I, Z	M2
F29	Deals and pipeline (9)	AC-11, AC-29	U, I, Z, E	M6
F30	Admin (2)	AC-30	I	M9
F32	CRM (1)	AC-31	I	M9
F34	Deals and pipeline (2)	AC-32	I, Z	M9
F36	Deals and pipeline (2)	AC-33	I, Z	M9
F37	Notifications (4)	AC-15	U, I	M2
F39	Admin (1)	AC-34	I, Z	M9
F40	Admin (4)	AC-35	I, Z	M1
F41	Admin (2)	AC-14	I, Z, D	M6
F42	Cross-cutting	AC-36	I, S	M1

Feature	Endpoints	AC	Tests	Milestone
F43	Platform (2)	AC-37	I, S	M1
F52	Favourites (3)	AC-38	I, Z	M9
F53	MFA (5)	AC-39	U, I, Z, S	M1
F54	Sessions (4)	AC-40	I, Z	M1
F55	Admin (3)	AC-41	I, Z, S	M5
F56	Privacy (7)	AC-42	I, Z, E	M1
F57	Configuration (2)	AC-43	U, I, Z	M1
F58	Configuration (1)	AC-44	U, I	M1
F59	Cross-cutting	AC-45	U, D, S	M1
F60	Admin (1)	AC-46	U, I, D	M1
F61	CRM (2)	AC-47	U, I	M9
Phase 2 (F15, F16, F23, F24, F31, F33, F35, F38, F49, F51)	Specified at Phase 2 planning	AC-16 for F33; others at planning	–	Phase 2
Phase 3 (F44–F48)	Specified at Phase 3 planning	At planning	–	Phase 3

24. Development milestones

Release 1 reaches a pilot in about week 21 and Release 1.1 by week 24, with 2 backend, 2 frontend, a half-time designer, 1 QA engineer and a product owner. This is a planning estimate until B12 and B13 are answered; with one backend and one frontend engineer, expect roughly 1.8 times as long.



MVP milestones · weeks from kickoff

Security and configuration come first because everything depends on them; the CRM comes second so brokers can work real leads while intake is built.

Milestone	Features	Exit check
M0 Discovery and setup	Repository, CI, environments, KMS keys, design tokens	Business checklist assigned; local stack runs with one command
M1 Foundations and security	F01, F02, F03, F40, F42, F43, F53, F54, F56, F57, F58, F59, F60	AC-01–AC-03, AC-12, AC-35–AC-37, AC-39, AC-40, AC-42–AC-46 pass
M2 Broker CRM core	F25, F26, F27, F28, F37	AC-13, AC-15, AC-26–AC-28 pass; two brokers use it on real leads
M3 Seller and buyer intake	F04, F06, F07, F08, F09, F10	AC-04, AC-17, AC-19–AC-22 pass; specialties confirmed (B2)
M4 Listings and discovery	F11, F12, F13, F14	AC-05, AC-06, AC-23 pass per enabled specialty; cities set (B3)
M5 NDA, access, data room	F17, F18, F19, F20, F21, F22, F55	AC-07–AC-10, AC-24, AC-25, AC-41 pass; NDA approved by counsel by week 13

Milestone	Features	Exit check
M6 Pipeline and audit viewer	F29, F41 (plus deal assignment for F26)	AC-11, AC-14, AC-29 pass
M7 Hardening	Penetration test, load test, accessibility audit, restore and key drill	No open critical or high findings
M8 Release 1 pilot	All 37 Release 1 features	Definition of done met; 3–5 live practices
M9 Release 1.1	F05, F30, F32, F34, F36, F39, F52, F61	AC-18, AC-30–AC-34, AC-38, AC-47 pass

Critical path: geography and hosting region by week 2; enabled specialties by week 9; cities by week 12; NDA, privacy notice approved by week 13 (privacy notice ideally by week 4); terms by week 18. If B11 confirms an existing pipeline, F61 moves into M2 (about one extra week).

25. Implementation plan

25.1 Repository structure

```
project-root/
  apps/
    web/                      # Next.js (App Router), TypeScript
      app/(public)/ (auth)/ (seller)/ (buyer)/ (broker)/ (admin)/
      features/<domain>/      # components, hooks, API calls per domain
      components/ui/          # Radix + Tailwind primitives
      lib/api-client.ts       # token in memory, silent refresh
    api/                      # Express, TypeScript
      src/
        server.ts  worker.ts
        platform/             # config, crypto, audit, auth, policy, rate-
limit, logger, storage, queue, email
        modules/<module>/     # routes, controller, service, repository,
model, policy, tests
        jobs/                 # scan, image-sanitise, email, reminders,
audit-seal, grant-expiry, retention
      migrations/             # migrate-mongo: roles, indexes, seeds
  packages/
    shared/                   # Zod schemas, enums, specialty registry,
permissions matrix, error codes
    config/                   # tsconfig, eslint, prettier presets
```

```
  infra/docker-compose.yml    # mongo (1-node replica set), redis, clamav,
minio, mailpit
  docs/                       # PRD, API, DATABASE, ARCHITECTURE, DECISIONS,
SECURITY, RUNBOOKS/
  .github/workflows/          # lint, typecheck, test, build, audit, image
scan
```

25.2 Initial setup (M0)

1. pnpm workspaces, TypeScript strict, ESLint, Prettier, pre-commit hooks.
2. `docker compose up` starts MongoDB (single-node replica set), Redis, ClamAV, MinIO and Mailpit; `pnpm dev` runs web, API and worker.
3. Local KMS stand-in, refused at startup in staging and production.
4. CI: install, lint, typecheck, unit, integration, build, dependency audit, image scan; branch protection.
5. Staging and production accounts, buckets (archive with object lock), KMS keys, secrets and email domain once B1 and B14 are answered.

25.3 Environment variables

Validated by a Zod schema at startup; the process exits on any missing value. `.env.example` has names only; staging and production read from the secrets manager.

Variable	App	Secret	Notes
`NEXT_PUBLIC_API_BASE_URL`, `NEXT_PUBLIC_APP_ENV`, `NEXT_PUBLIC_SENTRY_DSN`	web	No	Nothing secret uses `NEXT_PUBLIC_`
`NODE_ENV`, `PORT`, `APP_BASE_URL`, `API_BASE_URL`, `CORS_ALLOWED_ORIGINS`, `TRUST_PROXY_HOPS`	api	No	Exact origins
`MONGODB_URI`	api, worker	Yes	No write on `auditLogs`
`MONGODB_AUDIT_URI`	api, worker	Yes	Insert and find only on `auditLogs`
`REDIS_URL`	api, worker	Yes	TLS outside development
`JWT_SIGNING_KEY`, `JWT_KEY_ID`, `ACCESS_TOKEN_TTL_SECONDS` (900)	api	Key yes	Asymmetric

Variable	App	Secret	Notes
`REFRESH_TTL_DAYS_EXTERNAL` (30), `REFRESH_IDLE_DAYS_EXTERNAL` (7), `STAFF_SESSION_MAX_HOURS` (12), `STAFF_IDLE_MINUTES` (30)	api	No	Proposed
`KMS_PROVIDER`, `KMS_FIELD_KEY_ID`, `KMS_BLIND_INDEX_KEY_ID`	api, worker	IDs only	`local` in development only
`STORAGE_ENDPOINT`, `STORAGE_REGION`, `STORAGE_BUCKET_QUARANTINE`, `STORAGE_BUCKET_DOCUMENTS`, `STORAGE_BUCKET_AUDIT_ARCHIVE`, `STORAGE_ACCESS_KEY`, `STORAGE_SECRET_KEY`	api, worker	Keys yes	Prefer workload identity
`SIGNED_URL_DOWNLOAD_TTL_SECONDS` (60), `SIGNED_URL_UPLOAD_TTL_SECONDS` (600), `MAX_UPLOAD_BYTES` (26214400)	api	No	
`CLAMAV_HOST`, `CLAMAV_PORT`, `CLAMAV_MAX_SIGNATURE_AGE_HOURS` (24)	worker	No	Fail closed
`EMAIL_PROVIDER`, `EMAIL_FROM`, `EMAIL_API_KEY`	worker	Key yes	
`SENTRY_DSN`, `LOG_LEVEL`, `ALERT_WEBHOOK_URL`	api, worker	Webhook yes	
`MFA_ISSUER`, `DEFAULT_MARKET_KEY`	api	No	Brand (B15); seed only

25.4 Database setup

Managed replica set in the chosen region; `autoIndex` off outside development. Migration 001 creates the application and audit users and the `auditInsertOnly` role; 002 creates all indexes in section 17.3 and TTLs; 003 seeds pipeline stages, specialty settings and the confirmed market. Optimistic concurrency on deals, practices and listings. Audit, consent and NDA records are never deleted by the application.

25.5 Authentication

Order inside `platform/auth`: bcrypt hashing → registration with consent → email verification → login and lockout → JWT signing and verification middleware → refresh rotation with reuse detection → Redis denylist → sessions → staff invitations with forced

MFA → TOTP challenge and recovery codes → `requireRecentMfa(5 min)` step-up middleware.

25.6 Role-based authorisation

The section 12 matrix lives in `packages/shared/permissions.ts` (role × action → scope). `platform/policy` exposes `authorize(action, loader)` middleware and one unit-tested policy function per protected action (for example `canDownloadDocument(user, doc, grant)`). The authorisation suite is generated from the same matrix.

25.7 Database models (build order)

`marketConfigs`, `specialtySettings` → `users`, `organizations`, `sessions`, `refreshTokens` → `privacyNotices`, `consents`, `dataRequests` → `auditLogs`, `auditSeals` → `leads`, `tasks`, `activities`, `notifications` → `sellerProfiles`, `buyerProfiles`, `practices`, `practiceFinancials` → `listings`, `buyerInterests` → `ndaTemplates`, `ndaAcceptances`, `accessRequests`, `accessGrants`, `documents`, `breakGlassSessions` → `pipelineStages`, `deals` → Release 1.1: `verificationRequests`, `favourites`, `shortlists`, `offers`, `leadImports`.

25.8 API and frontend modules

Milestone	API modules	Frontend (screens)
M1	auth, mfa, sessions, admin-users, privacy, config, audit (write path)	(auth) S02–S05, S41–S44; (admin) S36, S45, S46
M2	leads, tasks, activities, notifications	(broker) S23–S25, S30; S16 drawer
M3	users, organizations, profiles, practices, buyers	(seller) S06, S08, S10–S12; (buyer) S07, S17; S26
M4	listings, moderation, interests	(public) S01, S40; (buyer) S18, S19, S21; S14; S34
M5	nda, access, documents, break-glass	S13, S15, S22, S29, S37, S47
M6	deals, pipeline, audit viewer	S27, S28, S38, S39
M9	verification, analytics, valuation-requests, shortlists, offers, favourites, admin-dashboard, lead-import	S09, S20, S31–S33, S35, S48

Forms import Zod schemas from `packages/shared`; the specialty section of the sale-request form renders from the registry, so enabling a specialty needs no new page.

25.9 Deployment

Containers `web`, `api` (2+), `worker`, `clamd` on a managed container service; managed MongoDB, Redis, storage, KMS, secrets manager in one region. Pipeline: merge → build images → staging → migrations → end-to-end and ZAP → manual approval → production with the same images. Rollback by redeploying the previous image; migrations are additive (expand, then contract later). Runbooks: restore, key rotation, break-glass, breach response, ClamAV outage.

25.10 Exact build order

1. Monorepo, tooling, CI, Docker Compose.
2. Config with environment validation; logger with redaction; error envelope and request IDs.
3. Crypto service and blind index.
4. Audit write path and sealing job.
5. Market and specialty configuration.
6. Registration with consent, verification, login, refresh, logout, lockout.
7. Sessions, denylist, MFA, staff invitations; permission matrix, policy layer, generated authorisation suite.
8. Rate limits, Helmet, CORS, body limits; health and readiness; Sentry.
9. Privacy notice, consents, data-rights requests.
10. Leads, tasks, activities, notifications; broker workspace screens.
11. Seller and buyer profiles; organisations.
12. Practices with specialty discriminators; financial intake; confidentiality; sale-request form.
13. Buyer qualification.
14. Moderation; listing generation with tier redaction; teasers; search; interests.
15. NDA templates and acceptance.
16. Access requests, veto, grants, revocation, expiry job.
17. Quarantine uploads, scan and image jobs, versions and review, signed downloads, access-log views.
18. Break-glass.
19. Deals, deal assignment, pipeline configuration, gates, Kanban; audit viewer and export.
20. Hardening.
21. Release 1 pilot.
22. Release 1.1: F61 (if not earlier), F34, F36, F05, F52, F32, F30, F39.

26. Risks and mitigation

The risks most likely to hurt the launch are business and legal, not technical: unclear ownership and promotion rules, and too few sellers willing to list.

#	Risk	Likelihood	Impact	Mitigation	Owner
R1	Ownership, licence-transfer or advertising rules restrict sales or promotion	Medium	High	Legal review per specialty before enabling; anonymised listings; no paid placement until cleared	Management, counsel
R2	Too few sellers	High	High	Start broker-led from existing relationships; measure approved listings per month	Management
R3	Anonymous listing re-identified	Medium	High	Bands, broker review, no photos before NDA, metadata stripping, scrape alerts	Product, security
R4	Confidential document leak	Low	Very high	Signed URLs, grants, sealed audit, no standing admin access, penetration test	Engineering
R5	Data-protection obligations arrive earlier or stricter	Medium	Medium	Consent, notice, deletion and breach processes in Release 1; counsel confirms dates	Counsel, engineering
R6	Informal financial records slow verification	High	Medium	Guided intake, checklist, broker verification; set expectations	Brokerage
R7	Valuation estimate wrong and damages trust	Medium	High	Phase 2 only after validation; show assumptions; never "certified"	Product
R8	Scope creep from Phase 2	High	Medium	Feature inventory gates; additions need a management decision and a dropped feature	Product owner
R9	Brokers keep using spreadsheets	Medium	High	CRM ships in M2; two brokers in design from week 1; lead import	Brokerage manager
R10	Competitor analysis from homepages only	Certain	Medium	Request demos; update section 4	Product

#	Risk	Likelihood	Impact	Mitigation	Owner
R11	Single-region outage	Low	Medium	Backups, tested restore, documented recovery	Engineering
R12	Regulatory rules differ by specialty	Medium	High	Legal review and research per specialty before enabling it	Management, counsel
R13	Loss of an encryption key makes data unreadable	Low	Very high	KMS deletion protection, two-person approval, quarterly key drill	Engineering
R14	Business decisions arrive late	Medium	High	Defaults in section 7 keep work moving; critical-path dates in section 24	Management

27. Future roadmap

Phase 2 starts only when the MVP has run real deals, and Phase 3 only when Phase 2 data justifies it.

Phase	Scope	Gate to start
1. MVP (Release 1, 1.1)	45 features (sections 13–14)	Legal sign-off on NDA, privacy notice, terms; market and specialties confirmed
2. Advanced workflows	F35 matching, F33 valuation, F24 diligence checklists, F23 document comments, F51 offers, F15 saved searches, F49 advisor access, F38 messaging, F31 analytics, F16 featured listings (after legal review); optional per-buyer watermarking	At least 10 deals end-to-end; multiples validated on real transactions; broker feedback reviewed
3. Scale	F44 e-signature, F45 lender integration, F46 AI assistance (optional), F47 external brokers and multi-organisation, F48 reporting; additional markets and specialties by configuration	Phase 2 adoption met; counsel confirms external-broker and e-signature rules; security review passed

Sequencing rules: valuation ships only after validation; external brokers only after a full quarter of audit, grant and revocation controls without a finding; a new specialty is enabled only after its legal review, research and contract tests.

28. Implementation-readiness checklist

Business (management)

- [ ] B1 geography confirmed in writing (week 2)
- [ ] B2 launch specialties confirmed (week 9)
- [ ] B3 launch cities confirmed (week 12)
- [ ] B4 brokerage model and B5 representation confirmed (week 3)
- [ ] B6 communication, B7 fees, B8 listing approval, B10 asking-price visibility decided (week 9)
- [ ] B11 existing pipeline described, with a sample export if any (week 2)
- [ ] B12 deadline and B13 team confirmed; plan re-estimated if different (week 1)
- [ ] B14 hosting provider and region; B15 brand and domain (week 2)
- [ ] Interviews: two brokers and two owners per launch specialty
- [ ] Pilot success criteria and review cadence agreed

Legal and compliance (counsel)

- [ ] Privacy notice, consent wording, data-rights process and retention approved (week 4)
- [ ] NDA text and B9 policy approved (week 13)
- [ ] Terms of use approved (week 18)
- [ ] Ownership, licence-transfer and advertising questions answered per specialty and market
- [ ] Data-residency advice for the chosen region

Engineering (tech lead)

- [ ] Monorepo, CI with branch protection, local stack
- [ ] Cloud accounts, KMS keys, buckets with object lock, secrets manager
- [ ] Environment schema enforced at startup
- [ ] Migrations 001–003 run in staging
- [ ] Permission matrix and generated authorisation suite in CI
- [ ] AC-ID test convention enforced
- [ ] Log-leak test and Sentry scrubbing
- [ ] Restore, key rotation, break-glass and breach runbooks
- [ ] Design tokens and component library agreed
- [ ] Penetration test booked for M7

Appendix A. Corrections from v1

#	v1 issue	Correction in this PRD
C01	India, dental-only and internal brokers listed as confirmed although not in the written brief	Reclassified as needing written confirmation (7.2)
C02	Dental-specific data model and fields	Specialty registry with common and specialty fields (17)
C03	Currency, fiscal year, regulators, bands hard-coded to India	Market configuration F58
C04	"35 features" while the inventory held 50, IDs to F51, F50 unassigned, out of order	Canonical inventory of 60 features, F50 marked unused (13)
C05	F14 had two priorities	Split into F14 interest and F52 favourites
C06	F46 phase "P2–P3"	Phase 3, optional
C07	MFA, sessions, break-glass, consent and data rights, encryption, audit write path, lead import had no IDs	Added as F53–F61
C08	Stage checklists P2 vs AC-11 requiring them in MVP	Gate checklists in MVP (F29); diligence checklists Phase 2 (F24)
C09	Access requests stored as interests but approved through a different resource	`accessRequests` collection and endpoint
C10	Favourites and shortlist endpoints with no collections	Collections added
C11	Screens and rules with no endpoint	34 endpoints added; 131 total
C12	Documents required a practice, but buyers upload proof of funds	Polymorphic document subject
C13	Register returned 409 for an existing email (enumeration)	202 either way
C14	ObjectIds in public URLs	Random public IDs
C15	Photo metadata kept (GPS can locate a clinic)	Images re-encoded, metadata stripped
C16	About half the MVP features had acceptance criteria	47 criteria covering every MVP feature

#	v1 issue	Correction in this PRD
C17	Several features without a milestone	Every feature mapped
C18	"Team of six" while listing about 6.5 FTE	Stated as 6.5 FTE
C19	Encrypted names blocked duplicate checks	HMAC blind index
C20	Audit log lacked tamper evidence	Insert-only connection, sealed chain, write-once archive
C21	Practice and listing states overlapped	Two state machines
C22	In-memory token vs server rendering not reconciled	Signed-in pages client-rendered
C23	Signed URL described as non-reusable	Reusable until expiry; never logged or emailed
C24	Suspension left the access token valid up to 15 minutes	Redis denylist
C25	API layered by type across 20+ modules	Feature-module layout

Appendix B. Technical decision log

ID	Decision	Alternative	Reason
TD-01	pnpm monorepo with shared Zod package	Separate repositories	One validation source; atomic changes
TD-02	Separate Express API; no Next.js API routes	Next.js route handlers	Mandated stack; security logic out of the web tier
TD-03	Private object storage with signed URLs	Cloudinary	Private buckets and access logs
TD-04	Access token in header, refresh in httpOnly cookie	Session cookie only	CSRF limited to one endpoint; revocable sessions
TD-05	Anonymised listing stored as its own document	Filtering at read time	A code mistake cannot leak fields that are not stored
TD-06	Application-level field encryption	At-rest only	Protects against database and backup access

ID	Decision	Alternative	Reason
TD-07	404 instead of 403 for hidden records	403	Does not reveal that a record exists
TD-08	Queue-based malware scanning	Synchronous scan	Fast uploads; responsive API
TD-09	Clickwrap NDA with hash, time, IP	E-signature now	Faster launch; e-sign after legal advice
TD-10	Deterministic matching and valuation	AI scores	Transparent and defensible
TD-11	Revenue bands before NDA	Exact revenue	Lower re-identification risk
TD-12	Staff MFA required	Optional	Staff hold the most sensitive access
TD-13	Specialty registry in code, enablement in data	Admin form builder; separate apps per specialty	Type-safe validation without overengineering
TD-14	Envelope encryption through one crypto service	Mongoose auto-decrypt getters	No accidental decryption in responses
TD-15	Sealed audit chain with write-once archive	Insert-only user alone	Tamper evidence
TD-16	Random public IDs in URLs	ObjectIds	Not guessable

Appendix C. Workflow diagrams (Mermaid source)

C1. Disclosure workflow

```
flowchart TD
  A["Buyer sees Tier 0-1 listing"] --> B["Buyer requests access"]
  B --> C{"Profile complete and broker-qualified?"}
  C -- No --> C1["Broker qualifies or declines with note"]
  C1 --> C
  C -- Yes --> D["Buyer accepts current NDA version"]
  D --> E["Broker reviews request"]
  E --> F{"Seller veto?"}
  F -- Yes --> G["Request rejected, buyer notified"]
  F -- No --> H["Grant with scope and expiry"]
  H --> I["Tier 2 fields and approved documents visible"]
  I --> J["Every view and download audited and sealed"]
  I --> K{"Expired or revoked?"}
  K -- Yes --> L["Access removed on next request"]
```

C2. Transaction lifecycle

```
stateDiagram-v2
  [*] --> NewLead
  NewLead --> BuyerQualified
  BuyerQualified --> NDA
  NDA --> InformationDisclosure
  InformationDisclosure --> DueDiligence
  DueDiligence --> InitialOffer
  InitialOffer --> Negotiation
  Negotiation --> LetterOfIntent
  LetterOfIntent --> LegalReview
  LegalReview --> FinalAgreement
  FinalAgreement --> Closing
  Closing --> OwnershipTransition
  OwnershipTransition --> PostSaleHandover
  PostSaleHandover --> [*]
  NewLead --> Lost
  DueDiligence --> Lost
  Negotiation --> Lost
  Negotiation --> Withdrawn
  Lost --> [*]
  Withdrawn --> [*]
```

C3. Practice intake and listing publication

```
stateDiagram-v2
  [*] --> Draft
  Draft --> Submitted
  Submitted --> InReview
  InReview --> ChangesRequested
  ChangesRequested --> Submitted
  InReview --> Rejected
  InReview --> Approved
  Approved --> Published
  Published --> Paused
  Paused --> Published
  Published --> UnderOffer
  UnderOffer --> Sold
  Published --> Withdrawn
  UnderOffer --> Withdrawn
```

C4. Core collection relationships

```
erDiagram
  ORGANIZATIONS ||--o{ USERS : employs
  USERS ||--o| BUYERPROFILES : has
  USERS ||--o| SELLERPROFILES : has
  USERS ||--o{ PRACTICES : owns
  PRACTICES ||--o{ PRACTICEFINANCIALS : has
  PRACTICES ||--o| LISTINGS : publishes
  PRACTICES ||--o{ DOCUMENTS : holds
  LISTINGS ||--o{ ACCESSREQUESTS : receives
  ACCESSREQUESTS ||--o| ACCESSGRANTS : creates
  NDATEMPLATES ||--o{ NDAACCEPTANCES : version
  PRACTICES ||--o{ DEALS : sells
  DEALS }o--|| PIPELINESTAGES : at
  DEALS ||--o{ TASKS : has
  LEADS ||--o{ TASKS : has
  DEALS ||--o{ ACTIVITIES : logs
  AUDITLOGS }o--|| AUDITSEALS : sealed_by
```